

Dedicatória

Aos meus queridos pais, Mario e Rosa, pela grande dedicação, educação e formação que concederam a mim e a meus irmãos.

EMILIO TISSATO NAKAMURA

A Cris e Lis, por suportarem minha ausência (sacrificando meu tempo, em que poderia estar com elas). Ao Senhor Jesus, por me capacitar e por prover todas as necessidades para este trabalho.

PAULO LÍCIO DE GEUS

Agradecimentos

Muitos merecem nossos agradecimentos por colaborarem direta ou indiretamente, desde a troca de idéias até as revisões de texto, para a obtenção deste livro. Dentre os atuais membros do LAS estão: Fabrício Sérgio de Paula, Francisco José Candeias Figueiredo, Alessandro Augusto, Jansen Carlo Sena, Diego de Assis Monteiro Fernandes, Flávio de Souza Oliveira, Marcelo Abdalla dos Reis, Cleymone Ribeiro dos Santos, Edmar Roberto Santana de Rezende, Benedito Aparecido Cruz, João Porto de Albuquerque Pereira, Hugo Kawamorita de Souza, Guilherme César Soares Ruppert, Richard Maciel Costa, Celso André Locatelli de Almeida, Arthur Bispo de Castro, Daniel Pupim Kano, Daniel Cabrini Hauagge, Luciana Aparecida Carrolo, Thiago Mathias Netto de Oliveira, Giselli Panontini de Souza, Evandro Leme da Silva, Weber Simões Oliveira. Há outros do IC-Unicamp, dos quais não conseguirei me lembrar.

Nossos agradecimentos também vão para o pessoal da Open Communications Security, que trouxeram uma valiosa contribuição técnica para o aprimoramento do conteúdo: Prof. Routo Terada, Pedro Paulo Ferreira Bueno, Marcelo Barbosa Lima, Paulo André Sant’Anna Perez, Keyne Jorge Paiva, Edson Noboru Honda, Carina Guirau Hernandez, Luiz Gustavo Martins Arruda. Obrigado também a todos os membros do time da Open pelo apoio.

Agradecimentos especiais vão a José Luis Barboza, da Robert Bosch Ltda, por iniciar a cooperação com o IC-Unicamp, e a Marcelo Fiori da Open Communications Security, por incentivar a publicação do livro e ceder o tempo de Emilio para a revisão final.

E o meu (Emilio) agradecimento em particular vai para Grace, pelo amor e paciência demonstrados não somente durante a escrita do livro, mas sempre.

Para esta segunda edição, os agradecimentos vão para todos os leitores que contribuíram com idéias, informações e *feedbacks* sobre a primeira edição do livro, em especial Ana Maria Gomes do Valle e Helen Mary Murphy Peres Teixeira.

Os agradecimentos também vão para João Porto de Albuquerque Pereira, Pedro Paulo Ferreira Bueno, Sergio Luís Ribeiro e Marcelo Barbosa Lima, que contribuíram com materiais, idéias e conversas que aprimoraram o conteúdo do livro.

Obrigado também a Marcos Antonio Denega, que acreditou no nosso trabalho, e a todos aqueles com quem pudemos interagir e aprimorar nossos conhecimentos.

Sobre este livro

Este livro contém fundamentos sobre segurança de redes de computadores, e seu foco está centrado no tratamento de ambientes cooperativos. Nesse sentido, o leitor encontrará seções descrevendo um grande número de técnicas, tecnologias e conceitos.

Este não é um livro de receitas de segurança, pronto para a aplicação no dia-a-dia, muito menos um texto sobre *hacking*, que ensine técnicas de invasão ou negação de serviço. O leitor interessado encontrará melhores textos para tais objetivos.

Entretanto, o leitor que desejar um embasamento sobre segurança de redes encontrará cobertura para a maioria dos conceitos envolvidos e poderá até mesmo encontrar respostas prontas para muitas de suas dúvidas.

O texto é voltado para o profissional de segurança, onde quer que seja sua atuação. É também adequado para um curso de segurança, dada a abrangência de sua cobertura. Em essência, contém o material que eu, Paulo, apresento normalmente no curso de segurança de redes oferecido pelo IC-Unicamp na graduação, pós-graduação e extensão, mas há bastante material extra, tornando-o útil para cursos em tópicos mais específicos sobre segurança de redes.

Sumário

Apresentação	1
Prefácio	3
PARTE I CONCEITOS BÁSICOS DE SEGURANÇA	7
1. Introdução	9
Estrutura básica	13
Parte I – Conceitos básicos de segurança	14
Parte II – Técnicas e tecnologias disponíveis para defesa	15
Parte III – Modelo de segurança para um ambiente cooperativo	17
2. O ambiente cooperativo	19
2.1 A informática como parte dos negócios	19
2.2 Ambientes cooperativos	22
2.3 Problemas nos ambientes cooperativos	23
2.4 Segurança em ambientes cooperativos	25
2.5 Conclusão	27

3. A necessidade de segurança	29
3.1 A segurança de redes	29
3.2 Maior evolução, maior preocupação com a segurança	33
3.3 Segurança como parte dos negócios	35
3.4 Como a segurança é vista hoje	37
3.5 Investimentos em segurança	39
3.6 Mitos sobre segurança	43
3.7 Riscos e considerações quanto à segurança	44
3.8 Segurança versus funcionalidades	45
3.9 Segurança versus produtividade	47
3.10 Uma rede totalmente segura	48
3.11 Conclusão	49
4. Os riscos que rondam as organizações	51
4.1 Os potenciais atacantes	51
4.2 Terminologias do mundo dos hackers	63
4.3 Os pontos explorados	64
4.4 O planejamento de um ataque	67
4.5 Ataques para a obtenção de informações	68
4.6 Ataques de negação de serviços	87
4.7 Ataque ativo contra o TCP	93
4.8 Ataques coordenados	100
4.9 Ataques no nível da aplicação	106
4.10 Conclusão	119
5. Novas funcionalidades e riscos: redes sem fio	121
5.1. Evolução e mudanças	121
5.2. Características de redes sem fio	124
5.3. Segurança em redes sem fio	125
5.4. Bluetooth	127
5.4.6. Autenticação no nível de enlace	138
5.5. WLAN	145
5.6. Conclusão	169

PARTE II	TÉCNICAS E TECNOLOGIAS DISPONÍVEIS PARA DEFESA	171
6. Política de segurança		173
6.1 A importância		173
6.2 O planejamento		174
6.3 Os elementos		177
6.4 Considerações sobre a segurança		179
6.5 Os pontos a serem tratados		181
6.6 A implementação		183
6.7 Os maiores obstáculos para a implementação		185
6.8 Política para as senhas		188
6.9 Política para firewall		193
6.10 Política para acesso remoto		194
6.11 Política de segurança em ambientes cooperativos		195
6.12 Estrutura de uma política de segurança		200
6.13 Conclusão		203
7. Firewall		205
7.1 Definição e função		205
7.2 Funcionalidades		208
7.3 A evolução técnica		211
7.4 As arquiteturas		230
7.5 O desempenho		238
7.6 O mercado		240
7.8 Teste do firewall		243
7.9 Problemas relacionados		245
7.10 O firewall não é a solução total de segurança		247
7.11 Conclusão		250

8. Sistema de detecção de intrusão -----	251
8.1 Objetivos -----	251
8.2 Características -----	253
8.3 Tipos -----	256
8.4 Metodologias de detecção -----	267
8.5 Inserção e evasão de IDS -----	274
8.6 Intrusion Prevention System (IPS) -----	278
8.7 Configuração do IDS -----	280
8.8. Padrões -----	281
8.9 Localização do IDS na rede -----	282
8.10 Desempenho -----	283
8.11 Forense computacional -----	284
8.11 Conclusão -----	286
9. A criptografia e a PKI -----	287
9.1 O papel da criptografia -----	287
9.2 A segurança dos sistemas criptográficos -----	294
9.3 As maiores falhas nos sistemas criptográficos -----	298
9.4 Os ataques aos sistemas criptográficos -----	299
9.5 Certificados digitais -----	303
9.6 Infra-estrutura de chave pública -----	304
9.7 Conclusão -----	315
10. Redes privadas virtuais -----	317
10.1 Motivação e objetivos -----	317
10.2 Implicações -----	320
10.3 Os fundamentos da VPN -----	320
10.4 O tunelamento -----	321
10.5 As configurações -----	321
10.6 Os protocolos de tunelamento -----	337
10.7 Gerenciamento e controle de tráfego -----	347
10.8 Desafios -----	348
10.9 Conclusão -----	350

11. Autenticação -----	351
11.1 A identificação e a autorização -----	351
11.2 Controle de acesso -----	362
11.3 Single Sign-On (SSO) -----	364
11.4 Conclusão -----	367
PARTE III MODELO DE SEGURANÇA PARA UM AMBIENTE COOPERATIVO -----	369
12. As configurações de um ambiente cooperativo ---	371
12.1 Os cenários até o ambiente cooperativo ----	371
12.2 Configuração VPN/firewall -----	395
12.3 Conclusão -----	400
13. Modelo de segurança para ambientes cooperativos -----	401
13.1 Os aspectos envolvidos no ambiente cooperativo -----	401
13.2 As regras de filtragem -----	404
13.3 Manipulação da complexidade das regras de filtragem -----	417
13.4 Integrando tecnologias – firewall cooperativo -----	423
13.5 Níveis hierárquicos de defesa -----	426
13.6 Modelo de teias -----	433
13.7 Conclusão -----	448
14 Conclusão -----	449
Bibliografia -----	453
Índice remissivo -----	469
Sobre os autores -----	473

Apresentação

Este livro teve origem a partir da dissertação de mestrado de Emilio, durante seus estudos no Instituto de Computação da Unicamp. Emilio foi o aluno que, após minha (Paulo) apresentação de um tema de pesquisa a ser patrocinado por uma empresa local, procurou-me repetidas e insistentes vezes afirmando que ele era o aluno certo para o projeto. Sua determinação me impressionou a ponto de eu decidir escolhê-lo para o projeto, e como os leitores poderão comprovar, foi uma ótima escolha.

O conhecimento do ambiente computacional da Robert Bosch Ltda, composto na época por vários milhares de máquinas e mais de uma centena de servidores, sob uma administração única, colocou-nos perante um desafio. Como administrar segurança em rede tão vasta e com tantas interações com outras empresas, revendedores e funcionários em viagem? As soluções tradicionais na literatura de segurança só contemplavam cenários canônicos, resumidos praticamente a usuários internos da Internet e um *Web site*. Muitas propostas de *firewalls* e suas topologias são encontradas nos artigos e livros do meio, dentre eles até mesmo o ensino no curso de Segurança de Redes no IC-Unicamp, mas nenhuma tratava de uma possível cooperação com outra empresa (*joint-ventures*).

Como várias outras empresas pioneiras no processo de informatização de suas relações comerciais (B2B, *business-to-business*), a Bosch tinha que desbravar áreas ainda não estudadas pela academia. Este em particular acabou se constituindo em um excelente caso para estudar o problema e propor soluções adequadas, devido à diversidade de interações a serem suportadas pela rede e seu aparato de segurança, especialmente o *firewall*. Esse processo durou pouco mais de dois anos e exigiu uma

quantidade significativa de esforço, especialmente de Emilio, em razão da diversidade de tecnologias de segurança a serem dominadas para atingir seu objetivo.

PAULO LÍCIO DE GEUS

paulo@securitybase.net

Para esta segunda edição, diversas inserções foram feitas, as quais refletem os temas que estão sendo mais discutidos pela comunidade. Além da bagagem adquirida pelos trabalhos diretos envolvendo a segurança da informação, a contribuição dos leitores foi fundamental para a ampliação do livro. O que se pode perceber com o *feedback* é que a segurança é contínua e a percepção sobre o assunto muda de acordo com a experiência de cada um. É aí que reside o grande desafio de quem estuda e trabalha com segurança da informação: não se pode esquecer que a segurança envolve diferentes aspectos (de negócios, de processos, humanos, tecnológicos, jurídicos, culturais, sociais) e que o entendimento desse conjunto de aspectos é que estabelece o nível de segurança de uma organização.

Assim, entender os riscos envolvidos com cada situação e com cada ambiente é fundamental para que a proteção adequada possa ser estabelecida. Afinal de contas, não é possível reduzir riscos que não se conhece. Esta segunda edição inclui novas figuras e novas tabelas que visam facilitar o entendimento dos problemas e dos conceitos, técnicas e tecnologias que podem ser utilizadas para a proteção de um ambiente. Além disso, foram incluídos materiais extras sobre novos ataques, o funcionamento de novos *worms*, novas tecnologias de defesa, como os sistemas de prevenção de intrusão, e novos casos com incidentes de segurança no Brasil e no mundo.

Além disso, um capítulo novo foi incluído e trata de uma das tecnologias que mais causam impacto na vida das pessoas: as redes sem fio (*wireless*). Os aspectos de segurança do padrão IEEE 802.11, usado em WLANs, e do Bluetooth, usado em distâncias menores, são discutidos nesse novo capítulo.

O desejo foi manter o livro o mais atual possível, com o tratamento dos assuntos que fazem e que farão parte de qualquer organização, e que sejam importantes para cursos de segurança de redes. Para isso, procuramos compartilhar ao máximo as experiências adquiridas nesse período.

Boa Leitura !!!

EMILIO TISSATO NAKAMURA

emilio@securitybase.net

Prefácio

Computadores e redes podem mudar nossas vidas para melhor ou para pior. O mundo virtual tem as mesmas características do mundo real e, e há tempos, os eventos de segurança, ataques e invasões a computadores deixaram de ser atividades solitárias e não destrutivas. Há muito mais envolvido nessas ações. Pensando nisso, é imperativa a preocupação em manter a segurança dos computadores e das redes que os conectam. Sob esse ponto de vista, e ao contrário da maneira passional que muitos textos utilizam, este livro trata dos aspectos de um modelo de segurança de uma forma íntegra e elegante. A visão da proteção dos computadores é feita diretamente, analisando o dilema com a devida objetividade. A abordagem é extremamente correta, deixando de lado o tratamento da velha batalha do 'bem contra o mal' e apresentando os eventos e as características de forma técnica e clara. O desenvolvimento é feito de tal maneira que os profissionais envolvidos com a administração dos sistemas, e de sua segurança, podem encontrar neste livro o conhecimento necessário para suas ações práticas diárias. Assim, esses agentes poderão estar preparados para defender suas instalações e, principalmente, entender a amplitude e as implicações de seus atos. Em resumo, este livro é uma boa opção para quem quer estar preparado.

Além desses aspectos, o texto fornece subsídios importantes para a educação e o preparo para a segurança e a convivência em um mundo interconectado. Um importante paralelo pode ser traçado com o que acontece fora dos computadores e das redes. Práticas e procedimentos de segurança devem fazer parte do dia-a-dia da sociedade digital, da mesma forma que as regras e práticas sociais, implícitas ou explícitas, nos remetem ao comportamento aceitável e correto na sociedade em que vivemos. Na medida em que as técnicas e as metodologias de segurança são abordadas de maneira objetiva e educativa, esta obra colabora na compreensão dessas

ações, principalmente no que diz respeito à importância do estabelecimento de políticas de segurança dentro das instituições e corporações.

Este livro é fruto do trabalho e da ampla experiência do autor junto a um projeto de pesquisa no Instituto de Computação da UNICAMP — Universidade Estadual de Campinas, São Paulo. Esse projeto, orientado pelo prof. Dr. Paulo Lício de Geus — também um respeitadíssimo pesquisador da área de segurança computacional —, definiu um modelo de segurança de redes para ambientes cooperativos. Este livro transpõe para usuários e profissionais, iniciantes ou avançados em segurança, as conclusões e as metodologias desenvolvidas e abordadas naquele trabalho. Todos os importantes aspectos de segurança atuais são tratados, desde a definição do ambiente a ser protegido, passando pelas ferramentas de proteção e detecção de invasão, até, finalmente, o estabelecimento de sistemas cooperativos seguros. Com certeza, esta é uma obra esmerada e de fácil assimilação, que preenche a necessidade de um texto genuinamente nacional na área de segurança de computadores e redes, unindo o formalismo técnico correto com a atividade prática adequada, ambos dosados na medida certa.

ADRIANO MAURO CANSIAN

adriano@ieee.org

Este livro chega no momento em que sistemas distribuídos ganham em escala, assumindo proporções globais; onde a *Web* e suas aplicações disponíveis na Internet assumem importância e interesse sem precedentes. A Internet está se transformando na grande via para o comércio, indústria, ensino e para o próprio governo. Termos como *E-Business*, *E-Contracting*, *E-Government*, *E-Learning*, *E-Voting* são forjados na literatura internacional e tornam-se presentes no nosso cotidiano, dando forma a uma ‘sociedade da informação’. As organizações melhoraram em eficiência e competitividade a partir do uso de novos paradigmas, envolvendo níveis de integração que podem ultrapassar suas fronteiras. Organizações cooperadas, por exemplo, passam a definir ‘empresas virtuais’ por meio da ligação de suas redes corporativas. Somado a tudo isso, temos ainda tecnologias emergentes, como a computação móvel, que ajudam a montar um cenário muito complexo sobre a rede mundial.

Entretanto, à medida que essa grande teia de redes locais, nacionais e de escala global vai sendo desenhada, a informação e os negócios tornam-se suscetíveis a novas ameaças, implicando em que a segurança assuma uma importância crítica nesses sistemas. Em anos recentes, um grande número de profissionais e organizações de padronização tem contribuído para o desenvolvimento de novas técnicas, padrões e programas nacionais de segurança. Apesar de todo esse esforço, é sempre difícil para um administrador de sistemas, um programador de aplicações ou um usuário final compreender todos os aspectos do problema da segurança, especialmente em sistemas de larga escala.

A segunda edição deste livro incorpora os mais recentes desenvolvimentos em termos de tecnologia e conhecimento sobre segurança em sistemas computacionais. Como a edição anterior, este livro é dirigido no sentido de fornecer, com muita

propriedade, o conhecimento dos princípios e a prática sobre a segurança em sistemas computacionais. As informações são apresentadas de uma maneira clara, para permitir que seus leitores, mesmo que iniciantes, possam avaliar as técnicas e a necessidade de segurança nos sistemas atuais. Ao mesmo tempo, o conteúdo é abrangente o necessário para que possa ser utilizado como um livro-texto em cursos de graduação e pós-graduação. É um instrumento útil para profissionais que atuam na área.

O livro apresenta um retrato geral das vulnerabilidades e ameaças a que estão sujeitos os sistemas computacionais nesse contexto de integração. Descreve os elementos necessários para que redes cooperativas possam apresentar propriedades de segurança. Para tal, uma abordagem metodológica é usada na descrição de seus conteúdos. De início, os autores se concentram nos problemas de segurança. Na segunda parte, são apresentados conceitos, princípios básicos, técnicas e tecnologias de segurança. As técnicas apresentadas estão relacionadas com os problemas descritos na parte anterior. Por fim, os autores, fazendo uso de suas experiências, propõem um modelo de segurança para redes cooperativas. Esse modelo está fundamentado nas técnicas e tecnologias descritas na Parte II.

O professor Paulo Lício de Geus, coordenador e principal idealizador do projeto deste livro, possui uma consistente atuação na área. Foi, por muitos anos, administrador da rede da Unicamp, onde acumulou uma experiência prática muito sólida. Atualmente, Paulo Lício conduz o Laboratório de Administração e Segurança de Sistemas (LAS) do Instituto de Computação da Unicamp, sendo responsável por importantes pesquisas e trabalhos acadêmicos na área de segurança em sistemas computacionais. As contribuições e atuações em eventos científicos fazem do professor um membro respeitado da emergente comunidade acadêmica brasileira da área de segurança. Suas relevantes contribuições na área de segurança foram determinantes em suas participações, como perito, no episódio da pane do painel da Câmara no Congresso Nacional e na avaliação do sistema de votação eletrônica do Tribunal Superior Eleitoral.

Por fim, credito o sucesso deste livro ao excelente nível de seus conteúdos e ao reconhecimento do trabalho do professor Paulo Lício. São poucas as publicações de livros técnicos que conseguem os números de venda atingidos pela primeira edição. Portanto, também não tenho dúvida sobre o êxito desta segunda edição.

JONI DA SILVA FRAGA
Professor Titular
DAS/UFSC

Parte I

Conceitos básicos de segurança

Esta seção inicia o leitor quanto aos problemas a serem tratados neste livro. As organizações de todos os tipos devem fazer parte do mundo virtual, que é a Internet: elas simplesmente não podem se dar ao luxo de não estar presentes nesse mundo, especialmente com as pressões da globalização. Ou será que é justamente a atual infra-estrutura de comunicação de dados que está incentivando e alimentando a globalização? Qualquer que seja a resposta, a Internet é indispensável, hoje, para qualquer organização.

Neste mundo virtual da Internet, muitos dos paradigmas, problemas e soluções do mundo real também se aplicam. Assim como no mundo real, onde existem propriedades privadas e organizações de comércio com dependências de acesso público (lojas), no mundo virtual existem máquinas de usuários (estações) e servidores de organizações, respectivamente. Assim como no mundo real, as propriedades e organizações virtuais necessitam de proteção e controle de acesso. Confiamos plenamente que você, leitor, não sai de casa sem se certificar de que as portas, janelas e o portão estejam trancados. Da mesma forma, uma loja na cidade é de acesso público, no sentido de qualquer pessoa poder entrar em suas dependências por ser potencialmente um cliente; porém, dependências internas da loja são vedadas a esses clientes em potencial.

Os mesmos critérios de segurança devem ser observados no mundo virtual, por meio de medidas estritas de segurança. Alguns paralelos interessantes são:

☛ **Firewalls:** Equivalentes ao controle de acesso na loja real, por intermédio de porteiros, vigias, limites físicos e portas.

- **Política de segurança:** Equivalente ao modelo de conduta do cidadão visitante na loja e de procedimentos por parte dos funcionários para garantir o bom comportamento social dos visitantes e da integridade do patrimônio da loja.
- **Separação entre rede pública (servidores externos) e rede interna:** equivalente à separação entre a parte pública da loja, onde os visitantes circulam, e a parte privada, onde somente os funcionários transitam.

Entretanto, as pessoas e organizações no mundo virtual interagem de várias maneiras, e o modelo de segurança mencionado anteriormente se mostra insuficiente para tratar da complexidade das comunicações possíveis no mundo virtual, fruto dos avanços tecnológicos. Esse é o ambiente cooperativo a que nos referimos neste texto, e que será caracterizado nos próximos capítulos, assim como as ameaças a que tal ambiente está exposto. As redes sem fio (*wireless*) e seus riscos envolvidos também serão discutidos.

Introdução

A necessidade de segurança é um fato que vem transcendendo o limite da produtividade e da funcionalidade. Enquanto a velocidade e a eficiência em todos os processos de negócios significam uma vantagem competitiva, a falta de segurança nos meios que habilitam a velocidade e a eficiência pode resultar em grandes prejuízos e falta de novas oportunidades de negócios.

O mundo da segurança, seja pensando em violência urbana ou em *hackers*, é peculiar. Ele é marcado pela evolução contínua, no qual novos ataques têm como resposta novas formas de proteção, que levam ao desenvolvimento de novas técnicas de ataques, de maneira que um ciclo é formado. Não é por acaso que é no elo mais fraco da corrente que os ataques acontecem. De tempos em tempos os noticiários são compostos por alguns crimes 'da moda', que vêm e vão. Como resposta, o policiamento é incrementado, o que resulta na inibição daquele tipo de delito. Os criminosos passam então a praticar um novo tipo de crime, que acaba virando notícia. E o ciclo assim continua. Já foi comprovada uma forte ligação entre seqüestradores e ladrões de banco, por exemplo, na qual existe uma constante migração entre as modalidades de crimes, onde o policiamento é geralmente mais falho.

Esse mesmo comportamento pode ser observado no mundo da informação, de modo que também se deve ter em mente que a segurança deve ser contínua e evolutiva. Isso ocorre porque o arsenal de defesa usado pela organização pode funcionar contra determinados

tipos de ataques; porém, pode ser falho contra novas técnicas desenvolvidas para driblar esse arsenal de defesa.

Alguns fatores podem ser considerados para que a preocupação com a segurança continua seja justificada:

- a) Entender a natureza dos ataques é fundamental: é preciso entender que muitos ataques são resultado da exploração de vulnerabilidades, as quais passam a existir devido a uma falha no projeto ou na implementação de um protocolo, aplicação, serviço ou sistema, ou ainda devido a erros de configuração e administração de recursos computacionais. Isso significa que uma falha pode ser corrigida, porém novos *bugs* sempre existirão;
- b) Novas tecnologias trazem consigo novas vulnerabilidades: é preciso ter em mente que novas vulnerabilidades surgem diariamente. Como novas tecnologias e novos sistemas são sempre criados, é razoável considerar que novas vulnerabilidades sempre existirão e, portanto, novos ataques também serão sempre criados. As redes sem fio (*wireless*), por exemplo, trazem grandes benefícios para as organizações e os usuários, porém trazem também novas vulnerabilidades que podem colocar em risco os negócios da organização;
- c) Novas formas de ataques são criadas: a própria história mostra uma evolução constante das técnicas usadas para ataques, que estão cada vez mais sofisticadas. A mistura de diferentes técnicas, o uso de tecnologia para cobrir vestígios a cooperação entre atacantes e a criatividade são fatores que tornam a defesa mais difícil do que o habitual;
- d) Aumento da conectividade resulta em novas possibilidades de ataques: a facilidade de acesso traz como consequência o aumento de novos curiosos e também da possibilidade de disfarce que podem ser usados nos ataques. Além disso, novas tecnologias, principalmente os novos protocolos de comunicação móvel, alteram o paradigma de segurança. Um cenário onde os usuários de telefones celulares são alvos de ataques e usados como porta de entrada para ataques a uma rede corporativa, por exemplo, é completamente plausível;
- e) Existência tanto de ataques direcionados quanto de ataques oportunistas: apesar de a maioria dos ataques registrados ser oportunístico, os ataques direcionados também existem em grande número. Esses ataques direcionados podem ser considerados mais perigosos, pois, existindo a intenção de atacar, a estratégia pode ser cuidadosamente pensada e estudada, e executada de modo a explorar o elo mais fraco da organização. Esses são, geralmente, os ataques que resultam em maiores prejuízos, pois não são feitos de maneira aleatória, como ocorre com os ataques oportunistas. Isso pode ser observado também pelo nível de agressividade dos ataques. Quanto mais agressivo é o ataque,

maior é o nível de esforço dispensado em um ataque a um alvo específico. É interessante notar também que a agressividade de um ataque está relacionada com a severidade, ou seja, maiores perdas;

- f) A defesa é mais complexa do que o ataque: para o *hacker*, basta que ele consiga explorar apenas um ponto de falha da organização. Caso uma determinada técnica não funcione, ele pode tentar explorar outras, até que seus objetivos sejam atingidos. Já para as organizações, a defesa é muito mais complexa, pois exige que todos os pontos sejam defendidos. O esquecimento de um único ponto faz com que os esforços dispensados na segurança dos outros pontos sejam em vão. Isso acaba se relacionando com uma das principais falácias do mundo corporativo: a falsa sensação de segurança. É interessante notar que, quando o profissional não conhece os riscos, ele tende a achar que tudo está seguro com o ambiente. Com isso, a organização passa, na realidade, a correr riscos ainda maiores, que é o resultado da negligência. Isso acontece com os *firewalls* ou com os antivírus, por exemplo, que não podem proteger a organização contra determinados tipos de ataques.
- g) Aumento dos crimes digitais: o que não pode ser subestimado são os indícios de que os crimes digitais estão se tornando cada vez mais organizados. As comunidades criminosas contam, atualmente, com o respaldo da própria Internet, que permite que limites geográficos sejam transpostos, oferecendo possibilidades de novos tipos de ataques. Além disso, a legislação para crimes digitais ainda está na fase da infância em muitos países, o que acaba dificultando uma ação mais severa para a inibição dos crimes.

Dentre os fatos que demonstram o aumento da importância da segurança, pode-se destacar a rápida disseminação de vírus e *worms*, que são cada vez mais sofisticados. Utilizando técnicas que incluem a engenharia social, canais seguros de comunicação, exploração de vulnerabilidades e arquitetura distribuída, os ataques visam a contaminação e a disseminação rápida, além do uso das vítimas como origem de novos ataques. A evolução dos ataques aponta para o uso de técnicas ainda mais sofisticadas, como o uso de códigos polimórficos para a criação de vírus, *worms*, *backdoor* ou *exploits*, para dificultar sua detecção. Além disso, ferramentas que implementam mecanismos que dificultam a adoção da forense computacional também já estão sendo desenvolvidos. Os canais ocultos ou cobertos (*covert channels*) tendem a ser usados para os ataques, nos quais os controles são enviados por túneis criados com o uso de HTTPS ou o SSH, por exemplo. O uso de 'pontes' de ataques e mecanismos do TCP/IP para dificultar a detecção e investigação igualmente tende a ser cada vez mais utilizado. Ataques a infra-estruturas envolvendo roteamento ou DNS, por exemplo, também podem ser realizados.

Alguns incidentes mostram que os prejuízos com a falta de segurança podem ser grandes. O roubo de 5,6 milhões de números de cartões de crédito da Visa e da MasterCard de uma administradora de cartões americana, em fevereiro de 2003 [JT 03], por exemplo, pode sugerir grandes problemas e inconvenientes para as vítimas. No Brasil, o roubo de mais de 152 mil senhas de acesso de grandes provedores de acesso, em março de 2003, resultou em quebra de privacidade e, em muitos casos, perdas bem maiores [REV 03]. No âmbito mundial, variações de *worms* como o Klez ainda continuam na ativa, mesmo passado mais de um ano desde seu surgimento. A primeira versão do Klez surgiu em novembro de 2001 e a versão mais perigosa, em maio de 2002; em março de 2003, o Klez era o *worm* mais ativo do mês [MES 03]. Em junho de 2002, um incidente de segurança envolvendo usuários de cinco dos maiores bancos e administradores de cartões de crédito do Brasil resultou em prejuízos calculados em R\$ 100 mil [TER 02], mostrando que incidentes envolvendo instituições financeiras estão se tornando cada vez mais comuns, seja no Brasil ou em outros países.

Outros incidentes notórios podem ser lembrados, como o que envolveu o *worm* Nimda, em setembro de 2001. Um alto grau de evolução pôde ser observado no Nimda, que foi capaz de atacar tanto sistemas Web quanto sistemas de e-mail. Antes do aparecimento do Nimda, um outro *worm*, o Code Red (e sua variação Code Red II), vinha, e ainda vem, causando grandes prejuízos, não somente às organizações que sofreram o ataque, mas à Internet como um todo. Causando lentidão na rede, o Code Red resultou em prejuízos estimados em 2,6 bilhões de dólares nos Estados Unidos, em julho e agosto de 2001. Outro notório evento foi a exploração em larga escala de ferramentas para ataques coordenados e distribuídos, que afetaram e causaram grandes prejuízos, durante 2000, a *sites* como Amazon Books, Yahoo, CNN, eBay, UOL e ZipMail. Somaram-se ainda ataques a *sites* de comércio eletrônico, notadamente o roubo de informações sobre clientes da CDNow, até mesmo dos números de cartões de crédito. Casos de 'pichações' de *sites* Web também são um fato corriqueiro, demonstrando a rápida popularização dos ataques a sistemas de computadores.

Porém, os ataques que vêm causando os maiores problemas para as organizações são aqueles que acontecem a partir da sua própria rede, ou seja, os ataques internos. Somado a isso, está o fato de as conexões entre as redes das organizações alcançarem níveis de integração cada vez maiores. Os ambientes cooperativos, formados a partir de conexões entre organizações e filiais, fornecedores, parceiros comerciais, distribuidores, vendedores ou usuários móveis, resultam na necessidade de um novo tipo de abordagem quanto à segurança. Em oposição à idéia inicial, quando o objetivo era proteger a rede da organização isolando-a das redes públicas, nos ambientes cooperativos o objetivo é justamente o contrário: disponibilizar cada

vez mais serviços e permitir a comunicação entre sistemas de diferentes organizações, de forma segura. A complexidade aumenta, pois agora a proteção deve ocorrer não somente contra os ataques vindos da rede pública, mas também contra aqueles que podem ser considerados internos, originados a partir de qualquer ponto do ambiente cooperativo.

É interessante observar que o crescimento da importância e até mesmo da dependência do papel da tecnologia nos negócios, somado ao aumento da facilidade de acesso e ao avanço das técnicas usadas para ataques e fraudes eletrônicos, resultam no aumento do número de incidentes de segurança, o que faz com que as organizações devam ser protegidas da melhor maneira possível. Afinal de contas, é o próprio negócio, em forma de bits e bytes, que está em jogo.

Assim, entender os problemas e as formas de resolvê-los torna-se imprescindível, principalmente porque não se pode proteger contra riscos que não se conhece. Este livro tem como principal objetivo apresentar os conceitos, as técnicas e as tecnologias de segurança que podem ser usados na proteção dos valores computacionais internos das organizações. Para isso, a formação de um ambiente cooperativo e as motivações para a implementação de uma segurança coerente serão discutidas. Os motivos que levam à adoção de determinada tecnologia também serão discutidos, bem como a integração das diversas tecnologias existentes, que é, de fato, o grande desafio das organizações.

ESTRUTURA BÁSICA

O livro é dividido em três partes: a Parte I, composta pelos capítulos 2, 3, 4 e 5, faz a ambientação dos problemas que devem ser enfrentados pelas organizações; a Parte II, formada pelos capítulos de 6 a 11, apresenta as técnicas, conceitos e tecnologias que podem ser utilizadas na luta contra os problemas de segurança vistos na Parte I. Já a Parte III (capítulos 12 e 13) apresenta o modelo de segurança proposto pelos autores, no qual os recursos apresentados na Parte II são aplicados no ambiente cooperativo.

O Capítulo 2 faz a apresentação de um ambiente cooperativo e as necessidades de segurança são demonstradas no Capítulo 3. Os riscos que rondam as organizações, representados pelas técnicas de ataque mais utilizadas, são discutidos no Capítulo 4. O Capítulo 5 trata das redes sem fio, que possuem uma importância cada vez maior na vida das pessoas, porém trazem consigo novos riscos.

A política de segurança, os *firewalls*, os sistemas de detecção de intrusão, a criptografia, as redes privadas virtuais e a autenticação dos usuários são discutidos, respectivamente, nos capítulos 6, 7, 8, 9, 10 e 11. Já o Capítulo 12 discute as configurações que podem fazer parte de um ambiente cooperativo, enquanto o

Capítulo 13 discute os aspectos de segurança envolvidos nesse tipo de ambiente e o modelo de gestão de segurança proposto. Ele é composto pela arquitetura do *firewall* cooperativo, o modo de minimizar a complexidade das regras de filtragem e o modelo hierárquico de defesa. Este último é destinado a facilitar a compreensão dos problemas de segurança inerentes a esse tipo de ambiente, resultando assim em menos erros na definição da estratégia de segurança da organização. Ainda no Capítulo 13, o Modelo de Teias tem como objetivo auxiliar no gerenciamento da complexidade da segurança. O Capítulo 14 traz a conclusão do livro.

A seguir, o leitor encontrará um resumo mais detalhado de cada capítulo.

PARTE I – CONCEITOS BÁSICOS DE SEGURANÇA

Capítulo 1 – Introdução

Capítulo 2 – O ambiente cooperativo

Este capítulo mostra a dependência cada vez maior da informática e das telecomunicações para o sucesso das organizações, o que faz com que um novo ambiente de extrema importância surja no âmbito computacional: o ambiente cooperativo. Como consequência, diversos novos problemas passam a ocorrer nesse ambiente, principalmente com relação à segurança dos seus recursos. As triangulações, nas quais uma organização A acessa as informações de C, por intermédio de sua comunicação com a organização B, é apenas um desses problemas que devem ser tratados. A complexidade de conexões e a heterogeneidade do ambiente também devem ser considerados.

Capítulo 3 – A necessidade de segurança

Neste capítulo, cujo enfoque é a natureza da segurança, discute-se questões sobre investimentos em segurança e os seus mitos. Faz-se também uma análise sobre a influência das medidas de segurança nas funcionalidades dos sistemas e na produtividade dos usuários. A segurança é necessária, porém sua estratégia de implementação deve ser bem definida, medindo-se custos e benefícios, pois a segurança total não é possível. A análise dos riscos possui um papel fundamental nesse contexto.

Capítulo 4 – Os riscos que rondam as organizações

Este capítulo apresenta os riscos a que as organizações estão sujeitas. Os possíveis atacantes e os métodos, técnicas e ferramentas utilizados por eles são apresen-

tados, mostrando que as preocupações com a segurança devem ser tratadas com a máxima atenção e cuidado, para que a continuidade dos negócios das organizações não seja afetada. É contra esses riscos que as organizações têm de lutar, principalmente através das técnicas, tecnologias e conceitos a serem discutidos na Parte II deste livro. Os riscos envolvem aspectos humanos, explorados pela engenharia social, e aspectos técnicos. Detalhes de alguns dos ataques mais conhecidos podem ser encontrados neste capítulo, incluindo análises de ferramentas de DDoS e de *worms* como o Nimda, o Code Red, o Klez, o Sapphire e o Deloder. Com o objetivo de ilustrar os passos utilizados pelos atacantes, os ataques foram agrupados em categorias que incluem a obtenção de informações sobre os sistemas alvo, passando por técnicas que incluem negação de serviço (*Denial of Service, DoS*), ataques ativos, ataques coordenados e ataques às aplicações e aos protocolos.

Capítulo 5 – Novas funcionalidades e riscos: redes sem fio

O uso de redes sem fio (*wireless*) vem aumentando substancialmente, resultando em um impacto significativo na vida das pessoas. Seja em distâncias mais longas (telefones celulares), em distâncias médias (*Wireless LAN, WLAN*) ou em curtas distâncias (Bluetooth), as redes sem fio facilitam o dia-a-dia das pessoas; no entanto, trazem consigo novos riscos. Elas apresentam diferenças essenciais se comparadas às redes com fio, de modo que protocolos de segurança foram definidos para a proteção dos acessos sem fio, principalmente para a autenticação e proteção no nível de enlace. Este capítulo discute os aspectos de segurança existentes nas redes sem fio, em particular no padrão IEEE 802.11 e Bluetooth.

PARTE II – TÉCNICAS E TECNOLOGIAS DISPONÍVEIS PARA DEFESA

Capítulo 6 – Política de segurança

O objetivo deste capítulo é demonstrar a importância da política de segurança, discutindo pontos como seu planejamento, seus elementos, os pontos a serem tratados e os maiores obstáculos a serem vencidos, principalmente em sua implementação. Alguns pontos específicos que devem ser tratados pela política também são exemplificados, como os casos da política de senhas, do *firewall* e do acesso remoto. A discussão estende-se até a política de segurança em ambientes

cooperativos, que possuem suas particularidades. Os bolsões de segurança característicos dos ambientes cooperativos são uma dessas particularidades.

Capítulo 7 – Firewall

Este capítulo trata de um dos principais componentes de um sistema de segurança o *firewall*, e tem como objetivo discutir a definição do termo *firewall*, que vem sofrendo modificações com o tempo, além de discutir a evolução que vem ocorrendo nesse importante componente de segurança. Os conceitos técnicos envolvidos, fundamentais para a escolha do melhor tipo de *firewall* para cada organização, são apresentados detalhadamente. As arquiteturas de um *firewall*, que influem substancialmente no nível de segurança, também são discutidas. Por fim, conclui-se que o *firewall* não pode ser a única linha de defesa para garantir a segurança de uma organização.

Capítulo 8 – Sistema de detecção de intrusão

O sistema de detecção de intrusão (*Intrusion Detection Systems* — IDS) constitui um componente de segurança essencial em um ambiente cooperativo. Neste capítulo serão discutidos os objetivos dos sistemas de detecção de intrusão e os tipos de sistemas que podem ser usadas para a proteção do ambiente. Os tipos de IDS e as metodologias de detecção utilizadas serão discutidos, bem como as limitações de cada abordagem. Sua localização na rede da organização influi diretamente nos resultados da detecção, de forma que ela é discutida no capítulo. Os sistemas que visam não apenas a detecção, mas também a prevenção dos ataques — sistemas de prevenção de intrusão (*Intrusion Prevention System* — IPS) — também são apresentados neste capítulo.

Capítulo 9 – A criptografia e a PKI

A criptografia é uma ciência que possui importância fundamental para a segurança, ao servir de base para diversas tecnologias e protocolos, tais como a *Secure Socket Layer* (SSL) e o *IP Security* (IPSec). Suas propriedades — sigilo, integridade, autenticação e não-repúdio — garantem o armazenamento, as comunicações e as transações seguras, essenciais no mundo atual. Este capítulo discute o papel da criptografia e os aspectos relacionados à sua segurança. A infra-estrutura de chaves públicas (*Public Key Infrastructure* — PKI), baseada na criptografia assimétrica, vem ganhando uma importância cada vez maior, principalmente nos ambientes cooperativos, e também será discutida neste capítulo.

Capítulo 10 – Rede privada virtual

As redes privadas virtuais (*Virtual Private Network* — VPN) possuem grande importância para as organizações, principalmente no seu aspecto econômico, ao permitir que as conexões físicas dedicadas de longa distância sejam substituídas pelas suas correspondentes a redes públicas, normalmente de curta distância. As VPNs permitem também a substituição das estruturas de conexões remotas, que podem ser eliminadas em função da utilização dos clientes e provedores VPN. Porém, essas vantagens requerem uma série de considerações com relação à segurança, pois as informações das organizações passam a trafegar por meio de uma rede pública. A criptografia associada a VPNs não é suficiente: este capítulo visa discutir a VPN e as implicações de segurança envolvidas, além dos principais protocolos disponíveis (L2TP, PPTP, IPSec) para a comunicação entre as organizações por intermédio de túneis virtuais.

Capítulo 11 – Autenticação

A autenticação é essencial para a segurança dos sistemas, ao validar a identificação dos usuários, concedendo-lhes a autorização para o acesso aos recursos. A autenticação pode ser realizada com base em alguma coisa que o usuário sabe, em alguma coisa que o usuário tem ou em alguma coisa que o usuário é, como será visto neste capítulo. O capítulo mostra também os pontos importantes a serem considerados no controle de acesso, que tem como base a autenticação dos usuários, e discute as vantagens e desvantagens do *Single Sign-On* (SSO), que tenta resolver um dos maiores problemas relacionados à autenticação — o mau uso das senhas.

PARTE III – MODELO DE SEGURANÇA PARA UM AMBIENTE COOPERATIVO

Capítulo 12 – As configurações de um ambiente cooperativo

Este capítulo apresenta os diversos cenários que representam as redes das organizações, cuja evolução (aumento dos números de conexões) leva à formação de ambientes cooperativos. Será visto que a complexidade aumenta a cada nova conexão, o que exige uma análise profunda das implicações envolvidas e das tecnologias necessárias que serão utilizadas na arquitetura de segurança da organização. Este

capítulo analisa as diversas configurações de componentes importantes para a segurança da organização, como o *firewall*, a *Virtual Private Network* (VPN), o *Intrusion Detection System* (IDS) e a *Public Key Infrastructure* (PKI), de acordo com as necessidades que vão surgindo com a evolução das conexões. As discussões deste capítulo culminam com a arquitetura do *firewall* cooperativo, que é conceituado no próximo capítulo.

Capítulo 13 – O modelo de segurança para ambientes cooperativos

Este capítulo tem como objetivo apresentar um modelo de segurança para o ambiente cooperativo. Os aspectos envolvidos com o ambiente cooperativo são discutidos, e em seguida são demonstradas as dificuldades existentes na definição e implementação das regras de filtragem. A seguir, será apresentada uma abordagem para a manipulação da complexidade das regras de filtragem utilizando-se o *iptables*. A arquitetura do *firewall* cooperativo também é apresentada, culminando na definição de cinco níveis hierárquicos de defesa, que visam minimizar a complexidade e tornar mais simples a administração da segurança em um ambiente cooperativo. Uma discussão sobre o gerenciamento da complexidade da segurança também é realizada, com a apresentação do Modelo de Teias.

Capítulo 14 – Conclusão

O ambiente cooperativo

Este capítulo mostra a importância cada vez maior da tecnologia da informação para organizações de toda natureza. A dependência cada vez maior da informática e da telecomunicação para o sucesso das organizações tem como resultado o surgimento de um novo ambiente de extrema importância: o ambiente cooperativo. Como consequência, novos desafios passam a fazer parte do cotidiano de todos, principalmente com relação à segurança dos seus recursos.

2.1 A INFORMÁTICA COMO PARTE DOS NEGÓCIOS

O mundo moderno e globalizado faz com que as organizações busquem o mais alto nível de competitividade, no qual novos mercados são disputados vorazmente. O concorrente, agora, pode estar em qualquer parte do mundo e, para superá-lo, é necessário, mais do que nunca, fabricar produtos de qualidade, prestar bons serviços e manter um bom relacionamento com os clientes, sejam eles internos ou externos. Como reflexo, a busca de diferencial competitivo e de novos mercados faz com que as relações comerciais internacionais sejam cada vez mais necessárias e mais fortes, como pode ser visto, por exemplo, no Mercado Comum do Sul (Mercosul).

Nesse cenário, a competitividade global é ditada principalmente pela velocidade, qualidade e eficiência – seja das decisões, das

implementações ou das comunicações. Dessa maneira, a infra-estrutura de telecomunicações, que permite a comunicação entre pessoas e recursos, deve ser bem projetada e bem dimensionada. Mais do que isso, o uso eficiente da tecnologia como meio de evolução dos negócios e de desenvolvimento de novas oportunidades é vital para a sobrevivência de qualquer organização.

O uso da tecnologia possui um sentido muito amplo, e deve-se tirar proveito das inovações tanto para a criação e desenvolvimento de produtos quanto para o estabelecimento de novos canais de relacionamento com os clientes. Um recente caso de sucesso no Brasil, referente ao uso da tecnologia para a expansão dos negócios, é o da rede Ponto Frio. A operação virtual da loja, que abrange o *site* na Internet e o telemarketing, vendeu mais do que qualquer uma das 350 lojas da rede em dezembro de 2002, atingindo somente nesse mês R\$ 13 milhões [AGE 03]. Enquanto que a loja virtual Submarino, que surgiu na Internet, faturou R\$ 130 milhões em 2002 [EXA 03], demonstrando a força das oportunidades criadas com o uso da tecnologia.

Vários outros casos de sucesso do uso da Internet para a realização de negócios podem ser vistos no Brasil. A Ford, por exemplo, movimentou, em 2001, mais de R\$ 4 bilhões em transações com outras empresas — *Business-to-Business* (B2B). A General Motors atingiu mais de R\$ 1 bilhão, em 2001, com a venda do veículo Celta no mercado direto com os consumidores — *Business-to-Consumer* (B2C) [EXA 02]. Em 2002, somente a General Motors vendeu 90 mil veículos pela Internet, com o mercado automobilístico brasileiro atingindo US\$ 1,1 bilhão em vendas online [EXA 03]. Já os bancos Bradesco e Itaú totalizaram, cada um, mais de R\$ 6 bilhões em transações eletrônicas em 2001 [EXA 02]. Outros números do mercado brasileiro podem ser vistos nas tabelas 2.1 (B2C), 2.2 (B2B) e 2.3 (Bancos e corretoras) [EXA 02].

Tabela 2.1 Números brasileiros do B2C de 2001. Fonte: Info100, da Revista *Info Exame*.

Os maiores do B2C no Brasil em 2001			
Ordem	Empresa	Transações (R\$ milhões)	Ramo de atividade
1	General Motors	1044,0	Automotivo
2	Mercado Livre	188,2	Leilão online
3	Carsale	90,5	Venda de carros
4	Americanas.com	71,4	Varejo
5	Submarino	71,1	Varejo
6	Ford	39,5	Automotivo
7	BuscaPé	38,3	Comparação de preços
8	Editora Abril	33,7	Comunicações
9	Decolar.com	33,0	Turismo
10	Farmácia em Casa	26,1	Farmacêutico

Tabela 2.2 Números brasileiros do B2B de 2001. Fonte: Info100, da Revista *Info Exame*.

Os maiores do B2B no Brasil em 2001			
Ordem	Empresa	Transações (R\$ milhões)	Ramo de atividades
1	Ford	4610,9	Automotivo
2	Mercado Eletrônico	2000,0	E-marketplace
3	Intel	1652,2	Computação
4	Genexis	1200,0	E-marketplace
5	Cisco	1196,4	Computação
6	Porto Seguro	780,3	Seguros
7	Grupo VR	600,0	Vale-refeição
8	Itaú Seguros	485,0	Seguros
9	Ticket Serviços	483,0	Serviços
10	VB Serviços	403,6	Vale-transporte

Tabela 2.3 Números brasileiros das transações de bancos e corretores de 2001. Fonte: Info100, da Revista *Info Exame*.

Os maiores bancos e corretores no Brasil em 2001			
Ordem	Empresa	Transações (R\$ milhões)	Ramo de atividade
1	Bradesco	6725,5	Banco
2	Itaú	6000,0	Banco
3	Unibanco	2800,0	Banco
4	Banco Real/ABN Amro	2250,4	Banco
5	BankBoston	1600,0	Banco
6	Santander	1496,2	Banco
7	Hedging-Griffo	241,0	Corretora
8	Socopa	104,1	Corretora
9	Souza Barros	60,0	Corretora
10	Banco1.net	9,6	Banco

Assim, a própria infra-estrutura de rede e a informática podem ser consideradas como duas das responsáveis pelo avanço da globalização. Em menor escala, essa infra-estrutura, no mínimo, contribuiu e possibilitou o avanço da globalização, andando ambas na mesma direção. Se antes a Revolução Industrial pôde ser vista, agora a Revolução Digital faz parte da vida de todos.

O papel da informática como parte do processo de negócios de qualquer organização pode ser verificado mais claramente pelo aumento dos investimentos realizados na área de Tecnologia da Informação. A pesquisa da Giga Information Group realizada no Brasil, por exemplo, mostrou que os investimentos em tecnologia da informação cresceram 5% em 2002, apesar das eleições e da retração do mercado mundial [ITW 02]. Outra pesquisa, realizada pela *International Data Corporation* (IDC), revelou em 2002 que 88% das 60 empresas da América Latina pesquisadas consideram a Internet uma importante ferramenta de negócios, tanto hoje como a curto e médio prazos [B2B 02].

Imagine uma falha em algum dos componentes da informática, que pode afetar negativamente os negócios da organização. No caso do comércio eletrônico, por exemplo, a indisponibilidade ou problemas em um *site* faz com que o usuário faça a compra no concorrente, pois bastam apenas alguns cliques no mouse para a mudança entre diferentes lojas virtuais.

2.2 AMBIENTES COOPERATIVOS

No mundo globalizado e de rápidos avanços tecnológicos, as oportunidades de negócios vêm e vão com a mesma rapidez desses avanços. Todos vivenciam uma época de grandes transformações tecnológicas, econômicas e mercadológicas. Grandes fusões estão acontecendo, implicando também na fusão de infra-estruturas de telecomunicações, o que pode resultar em sérios problemas relacionados à segurança.

Além das fusões entre as organizações, as parcerias estratégicas e as formas de comunicação avançam de tal modo que a infra-estrutura de rede — de vital importância para os negócios — passa a ser uma peça fundamental para todos. Esse contexto atual, de grandes transformações comerciais e mercadológicas, somado à importância cada vez maior do papel da Internet, faz com que um novo ambiente surja, no qual múltiplas organizações trocam informações por meio de uma rede integrada. Informações técnicas, comerciais e financeiras, necessárias para o bom andamento dos negócios, agora trafegam por essa rede que conecta matrizes de empresas com suas filiais, seus clientes, seus parceiros comerciais, seus distribuidores e todos os usuários móveis.

A complexidade dessa rede heterogênea atinge níveis consideráveis, o que implica em uma série de cuidados e medidas que devem ser tomados, principalmente com relação à proteção das informações que fazem parte dessa rede. Esse ambiente, em que a rápida e eficiente troca de informações entre matrizes, filiais, clientes, fornecedores, parceiros comerciais e usuários móveis é um fator determinante de sucesso, é chamado de ambiente cooperativo.

O ambiente cooperativo é caracterizado pela integração dos mais diversos sistemas de diferentes organizações, nos quais as partes envolvidas cooperam entre si, na busca de um objetivo comum: velocidade e eficiência nos processos e nas realizações de negócios, que representam os elementos-chave para o sucesso de qualquer tipo de organização. A formação de um ambiente cooperativo (Figura 2.1), com as evoluções que ocorrem nas conexões das organizações e suas respectivas implicações, pode ser vista com detalhes no Capítulo 12.

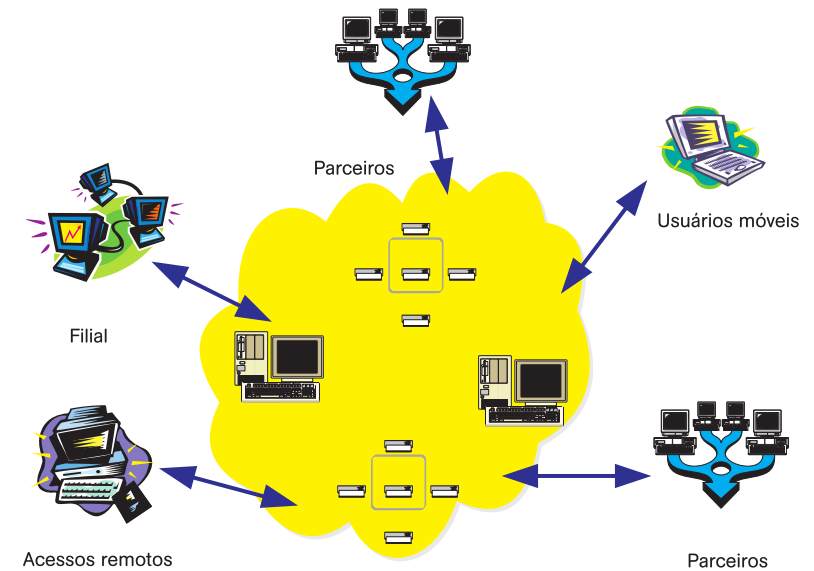


Figura 2.1 O ambiente cooperativo — diversidade de conexões.

2.3 PROBLEMAS NOS AMBIENTES COOPERATIVOS

A propriedade determinante dos ambientes cooperativos é a complexidade que envolve a comunicação entre diferentes tecnologias (cada organização utiliza a sua), diferentes usuários, diferentes culturas e diferentes políticas internas. O conjunto de protocolos da suíte TCP/IP e a Internet possibilitaram o avanço em direção aos ambientes cooperativos, ao tornar possíveis as conexões entre as diferentes organizações, de modo mais simples e mais barato que as conexões dedicadas. Porém, essa interligação teve como consequência uma enorme implicação quanto à proteção dos valores de cada organização.

Algumas situações que refletem o grau de complexidade existente nos ambientes cooperativos podem ser vistas quando são analisadas, por exemplo, as conexões entre três organizações (A, B e C). Como proteger os valores da organização A, evitando que um usuário da organização B acesse informações que pertencem somente à organização A?

Pode-se supor uma situação em que os usuários da organização B não podem acessar informações da organização A, porém os usuários da organização C podem fazê-lo. Como evitar que os usuários da organização B acessem informações da

organização A, por meio da organização C? Como pode ser visto na Figura 2.2, isso constitui um caso típico de triangulação, na qual uma rede é utilizada como ponte para uma outra rede. Neste exemplo, usuários da organização B podem acessar as informações da organização A, o que é proibido, utilizando a estrutura da organização C como ponte.

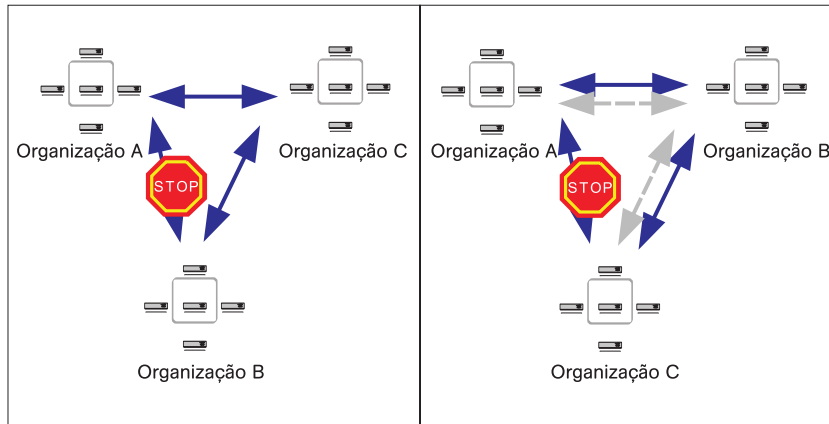


Figura 2.2 O perigo das triangulações.

Os problemas decorrentes dessa situação são gigantescos, pois a organização B pode ter acesso a informações confidenciais da organização A, sem que ela sequer tome conhecimento desse fato, pois o acesso ocorre por intermédio da organização C.

Além das triangulações, um outro problema que pode ocorrer em um ambiente cooperativo é o aumento da complexidade dos níveis de acesso. Isso pode ser visto em um exemplo no qual os usuários da organização A podem acessar todos os recursos da organização, enquanto os usuários da organização cooperada B podem acessar somente determinados recursos específicos, como, por exemplo, informações sobre produtos e o setor financeiro. Somado a isso, há o fato de que os usuários da Internet não podem acessar nenhum recurso da organização A, enquanto a organização C tem acesso irrestrito aos recursos da organização A. Essa situação demonstra o grande desafio de controlar os acessos em diferentes níveis, que pode se tornar mais complexo ainda, se diferentes usuários da organização B necessitam acessar diferentes recursos da organização A. Ainda nesse exemplo, pode-se ver novamente o problema da triangulação, de modo ainda mais crítico: os usuários da

Internet podem chegar à organização A, caso a organização B ou C tenha acesso à Internet (Figura 2.3).

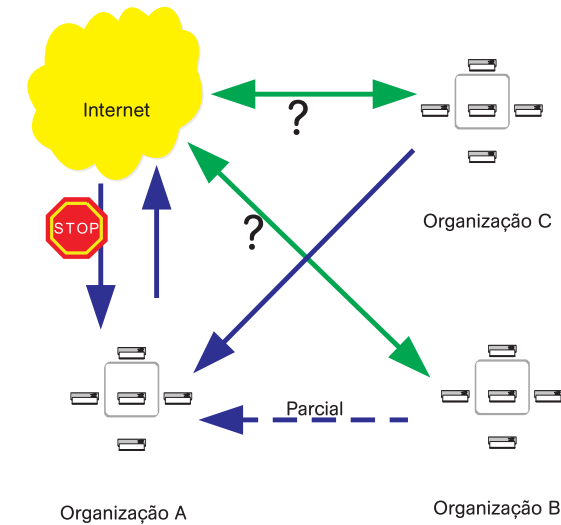


Figura 2.3 Os diferentes níveis de acesso somados ao perigo das triangulações.

A divisão entre os diferentes tipos de usuários, os desafios a serem enfrentados no ambiente cooperativo e a complexidade que envolve a segurança desses ambientes são analisados, com detalhes, no Capítulo 13.

2.4 SEGURANÇA EM AMBIENTES COOPERATIVOS

Os problemas a serem resolvidos nos ambientes cooperativos refletem fielmente a situação de muitas organizações atuais que buscam a vantagem competitiva por meio da necessária utilização da tecnologia. O ambiente cooperativo é complexo, e a segurança necessária a ser implementada é igualmente complexa, envolvendo aspectos de negócios, humanos, tecnológicos, processuais e jurídicos.

Este livro irá enfocar com maior ênfase os aspectos tecnológicos relacionados à segurança em ambientes cooperativos. Porém, isso não significa que eles tenham maior relevância com relação aos outros. Todos os aspectos são de extrema importância e devem ser considerados na implantação da segurança nos ambientes cooperativos.

De fato, a tecnologia faz parte de um pilar que inclui ainda os processos e as pessoas, que devem ser considerados para a elaboração de uma estratégia de segu-

rança coerente, de acordo com os aspectos de negócios da organização, respeitando sempre os aspectos jurídicos. A segurança em ambientes cooperativos será o resultado do conjunto de esforços para entender o ambiente e as tecnologias, saber como utilizá-las e implementá-las de modo correto. O livro visa auxiliá-lo na busca da segurança, identificando os pontos da infra-estrutura de rede a serem protegidos, apontando os principais perigos existentes, discutindo tecnologias relacionadas à segurança e propondo um modelo de segurança que englobe técnicas, metodologias e tecnologias de segurança.

Embora haja uma grande variedade de tecnologias e técnicas de segurança, que serão apresentadas no decorrer do livro, o administrador de segurança passa por grandes dificuldades no sentido de saber o que fazer para proteger sua rede, ficando, muitas vezes, completamente ‘perdido’ quanto às ações a serem tomadas. O *firewall* cooperativo, o modo de definir as regras de filtragem e o modelo hierárquico de defesa visam justamente auxiliar no processo de proteção da rede, por meio da apresentação das técnicas, tecnologias e arquiteturas mais adequadas para cada situação, independentemente do produto a ser utilizado.

Algumas questões que serão discutidas neste livro são:

- ☛ Por que a segurança é tão importante em todas as organizações?
- ☛ Por que a segurança é um dos habilitadores de negócios em um ambiente cooperativo?
- ☛ Quais são os maiores riscos que rondam as organizações?
- ☛ Qual é a importância e a necessidade da educação dos usuários?
- ☛ Qual é a importância e a necessidade de uma política de segurança?
- ☛ Quais são as fronteiras entre as organizações no ambiente cooperativo?
- ☛ Como um *firewall* funciona, e quais as diferenças existentes entre eles?
- ☛ Quais são os maiores problemas envolvendo *firewalls* e o ambiente cooperativo?
- ☛ Como resolver os problemas de regras de filtragem, inerentes ao ambiente cooperativo?
- ☛ Como implementar e garantir um nível de hierarquia entre as comunicações das diversas organizações no ambiente cooperativo?
- ☛ Qual tecnologia utilizar para garantir a proteção dos valores da organização? *Firewall*, sistema de detecção de intrusão (*Intrusion Detection System*, IDS), criptografia, autenticação de dois fatores, biometria, *Single Sign-On* (SSO), infra-estrutura de chaves públicas (*Public Key Infrastructure*, PKI), *IP Security* (IPSec), rede privada virtual (*Virtual Private Network*, VPN)?
- ☛ Quais os aspectos de segurança que devem ser considerados em um ambiente sem fio (*wireless*)?

- ☛ Como integrar as diversas tecnologias disponíveis?
- ☛ Enfim, como garantir a segurança nesse ambiente cooperativo?

2.5 CONCLUSÃO

Este capítulo discutiu a importância da informática para os negócios de todas as organizações. A necessidade cada vez maior de conexões resulta em uma complexidade nas configurações de redes de todos os envolvidos. Com isso, é formado um ambiente cooperativo que traz consigo uma série de implicações de segurança, principalmente quanto aos limites entre as redes e aos perigos de triangulações. A formação de um ambiente cooperativo será mostrada com detalhes no Capítulo 12, na Parte III, que apresenta, ainda, a forma de trabalhar com as diferentes técnicas, tecnologias e conceitos de segurança.

A necessidade de segurança

Neste capítulo, no qual a segurança tem todo o enfoque, no qual serão discutidas questões sobre investimentos em segurança e os seus mitos, bem como a relação da segurança com os negócios, as funcionalidades, a produtividade e os riscos envolvidos. Também serão abordados os aspectos da segurança de redes e a impossibilidade de se ter uma rede totalmente segura.

3.1 A SEGURANÇA DE REDES

A informática é um instrumento cada vez mais utilizado pelo homem, o qual busca incessantemente realizar seus trabalhos de modo mais fácil, mais rápido, mais eficiente e mais competitivo, produzindo, assim, os melhores resultados. A rede é uma das principais tecnologias, permitindo conexões entre todos os seus elementos, que vão desde roteadores até servidores que hospedam o *site* Web da organização e o banco de dados dos clientes, passando ainda por sistemas financeiros e *Customer Relationship Management* (CRM). Esses recursos disponibilizados pela rede representam, na Era da Informação, até mesmo o próprio negócio das organizações. Isso faz com que sua flexibilidade e facilidade de uso resultem em maior produtividade e na possibilidade de criação de novos serviços e produtos, e conseqüentemente em maiores lucros para a organização.

A confiabilidade, integridade e disponibilidade dessa estrutura de rede passam, assim, a ser essenciais para o bom andamento das

organizações, fazendo com que elas precisem ser protegidas. A proteção visa, sob esse ponto de vista, a manutenção do acesso às informações que estão sendo disponibilizadas para os usuários. Isso significa que toda informação deve chegar aos usuários de uma forma íntegra e confiável. Para que isso aconteça, todos os elementos de rede por onde a informação flui até chegar ao seu destino devem estar disponíveis, e devem também preservar a integridade das informações. O sigilo também pode ser importante; forma junto com a integridade e a disponibilidade formam as propriedades mais importantes para a segurança (Figura 3.1).



Figura 3.1 As propriedades mais importantes da segurança.

A segurança de redes, assim, é uma parte essencial para a proteção da informação, porém uma boa estratégia que deve ser levada em consideração são os aspectos humanos e processuais de uma organização. Isso é importante porque outros métodos de ataques, além dos tecnológicos, afetam os níveis de segurança de uma organização. Este livro, porém, manterá o enfoque nos aspectos tecnológicos da segurança, não significando, que esse seja o aspecto mais importante. A Figura 3.2 mostra os aspectos que devem ser considerados na proteção da informação, os quais incluem ainda os aspectos jurídicos e negócios de negócios que direcionam efetivamente a estratégia de segurança de cada tipo de organização.

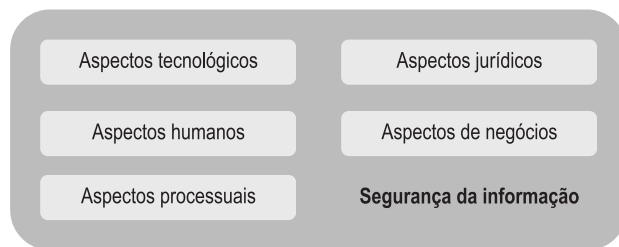


Figura 3.2 Os aspectos envolvidos na proteção da informação.

Assim, a segurança de redes, que pode prover grande parte da manutenção da disponibilidade, integridade e sigilo das informações, significa, na realidade, muito mais do que a proteção contra *hackers*, maus funcionários ou vírus. A segurança significa permitir que as organizações busquem seus lucros, os quais são conseguidos por meio de novas oportunidades de negócios, que são resultado da flexibilidade, facilidade e disponibilidade dos recursos de informática. Portanto, a segurança deve ser considerada não apenas uma proteção, mas o elemento habilitador dos negócios da organização. De fato, pesquisas indicam que os consumidores deixam de realizar negócios via Internet quando não confiam na segurança de um *site* [IDG 01].

A importância da segurança pode ser reforçada ainda mais quando se vê as novas oportunidades de negócios que surgem no mundo digital, condicionando seu sucesso à eficiência da estratégia de segurança. Em alguns casos, a falta de segurança é traduzida na negativa de ser usada uma novidade tecnológica. Algumas dessas oportunidades que podem ser exploradas são:

- **E-marketing:** Site Web.
- **E-sales:** Venda de produtos e serviços pela rede.
- **E-service:** Como as referências cruzadas de livros de interesse dos clientes, pela Amazon Books.
- **E-support:** Como a Federal Express, que informa a situação atual da carga, em tempo real.
- **E-supply:** Construção e integração da cadeia de fornecimento entre seus fornecedores e clientes.
- **E-business:** Relação de negócios entre parceiros de negócios.
- **E-marketplace:** Pontos de encontro virtuais entre compradores e fornecedores.
- **E-engineering:** Desenvolvimento de produtos de modo colaborativo.
- **E-procurement:** Relacionamento entre fornecedores e prestadores de serviços.
- **E-government:** Relacionamento entre o governo e os cidadãos.
- **M-commerce:** Comércio eletrônico via terminais móveis.

De fato, os números comprovam o grande crescimento dos negócios realizados via Internet no Brasil e no mundo. Segundo a pesquisa feita pela e-Consulting [EXA 03-2], o volume do comércio eletrônico brasileiro saltou de 2,1 bilhões de dólares em 2001 para 5,1 bilhões de dólares em 2002. No âmbito mundial, o número chegou a 1.167 bilhões de dólares em 2002. No Brasil, o volume de negócios *Business-to-Business* (B2B) passou de 1,6 bilhão de dólares em 2001 para 3,7

bilhões de dólares em 2002, enquanto o *Business-to-Consumer* (B2C) movimentou 1,42 bilhão de dólares em 2002, contra 0,5 bilhão de dólares em 2001. Já o *Business-to-Government* (B2G) brasileiro movimentou, em 2002, 1,2 bilhão de dólares [EXA 03-2]. Esses dados demonstram o crescimento cada vez maior do papel do comércio eletrônico para as organizações. A disponibilidade, o sigilo e a integridade das informações têm uma importância imensurável nesse cenário, que cresce cada vez mais.

Dessa maneira, a segurança deve ser vista como o elemento que permite que novas oportunidades sejam exploradas de forma concreta, de maneira que, sem ela, não existem negócios, pelo menos a longo prazo. Diversos tipos de ataques que comprometem a existência de negócios serão descritos no decorrer deste livro. A maior indicação de perigo está no fato de as pesquisas mostrarem um aumento no número de incidentes de segurança envolvendo a Internet. O CERT Coordination Center [CER 03], operado pela Carnegie Mellon University, comprova esse número, mostrando que em 2002 foram reportados 82.094 incidentes de segurança, que representam um volume 56% maior do que em 2001. O número de vulnerabilidades reportadas pelo CERT em 2002 também foi considerável, atingindo 4.129 vulnerabilidades em 2002, contra 2.437 em 2001, ou seja, um crescimento de quase 70%. A Figura 3.3 mostra a evolução do número de incidentes reportados ao CERT desde 1988, enquanto que a Figura 3.4 mostra a evolução das vulnerabilidades reportadas, desde 1995. No Brasil, o NBSO [NBSO 03], que constitui o Grupo de Resposta a Incidentes para a Internet Brasileira mantido pelo Comitê Gestor da Internet no Brasil, também observou um grande aumento do número incidentes reportados. Em 2001, foram reportados 12.301 incidentes, enquanto que em 2002 foram 25.092 incidentes reportados, o que representa um aumento de mais de 100%.

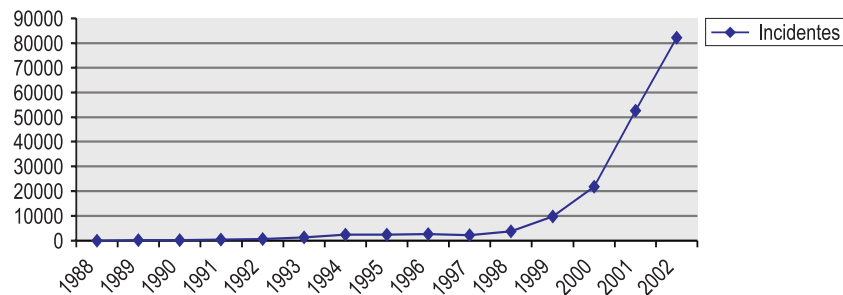


Figura 3.3 Crescimento dos incidentes reportados pelo CERT/CC, de 1988 a 2002.

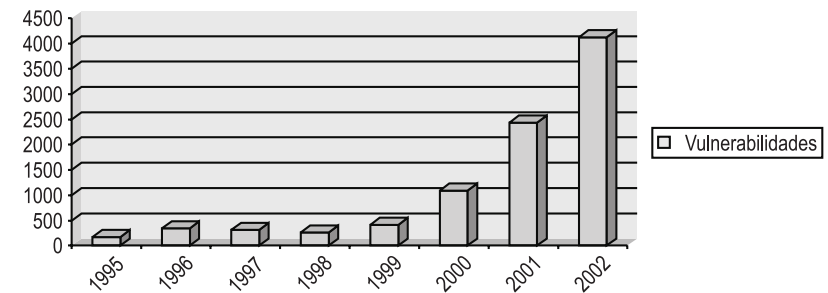


Figura 3.4 Crescimento das vulnerabilidades reportadas pelo CERT/CC, de 1995 a 2002.

3.2 MAIOR EVOLUÇÃO, MAIOR PREOCUPAÇÃO COM A SEGURANÇA

Nos tempos do mainframe, os aspectos de segurança eram simples, relacionados basicamente com o nome de usuário e sua senha [DID 98]. Atualmente, o alto grau de conectividade e a grande competitividade trouxeram, além dos seus grandes benefícios, outros tipos de problemas inerentes às novas tecnologias. Os avanços tecnológicos vêm resultando em grandes oportunidades de negócios, porém, quanto maior essa evolução, maiores as vulnerabilidades que aparecem e que devem ser tratadas com a sua devida atenção. Alguns culpam a própria indústria pelo aumento das vulnerabilidades, acusando-a de não estar dando a atenção necessária aos aspectos de segurança de seus produtos. De fato, muitas organizações estão mais interessadas em finalizar rapidamente os seus produtos para colocá-los no mercado antes de seus concorrentes. Isso acontece até mesmo na indústria de tecnologias de segurança, onde vários produtos já apresentaram falhas.

O que pode ser observado, porém, é que não é um fato isolado, mas sim um conjunto de fatores, que acaba acarretando o aumento das vulnerabilidades e a crescente preocupação com a proteção:

- A competitividade e a pressa no lançamento de novos produtos.
- O alto nível de conectividade.
- O aumento do número de potenciais atacantes.
- O avanço tecnológico, que resulta em novas vulnerabilidades intrínsecas.

- ☛ O aumento da interação entre organizações, resultando nos ambientes cooperativos.
- ☛ A integração entre diferentes tecnologias, que multiplica as vulnerabilidades.
- ☛ A Era da Informação, onde o conhecimento é o maior valor.
- ☛ A segurança representando a habilitação de negócios.

A evolução do mercado, da concorrência, dos negócios e da tecnologia continua comprovando a importância da segurança. Por exemplo, as redes sem fio (*wireless*), mostradas no Capítulo 5, trouxeram muitos benefícios para seus usuários, mas também muitas mudanças nos aspectos de segurança. Preocupações antes não tão fortes, como o acesso físico à rede, passaram a ser muito mais relevantes, motivando a criação de novos protocolos de segurança. Porém, no Capítulo 5 será mostrado que, mesmo esses protocolos, como o *Wired Equivalent Protocol* (WEP), usado no padrão *Institute of Electrical and Electronics Engineers* (IEEE) 802.11, possui falhas que possibilitam ataques. Outros fatos demonstram a relação entre a evolução tecnológica e os aspectos de segurança:

- ☛ O surgimento do conjunto de protocolos *Transmission Control Protocol/Internet Protocol* (TCP/IP) e o advento da Internet fizeram com que o alcance das invasões crescesse em proporções mundiais, uma vez que qualquer um pode atacar qualquer alvo.
- ☛ A criação de linguagens macro em aplicativos como o Word ou o Excel fez surgir uma nova geração de vírus, que se espalham com uma velocidade nunca antes vista (também por intermédio de e-mails), pois qualquer tipo de arquivo de dados pode estar infectado, e não mais somente os arquivos executáveis e os discos de inicialização.
- ☛ A Web e as linguagens criadas para a Internet, como o JavaScript ou o ActiveX, são de difícil controle e podem causar sérios problemas, caso contenham códigos maliciosos e sejam executados em uma rede interna.
- ☛ A sofisticação dos e-mails que passaram a interpretar diversos tipos de códigos e a executar diversos tipos de arquivos. Eles são explorados de forma bastante intensa pelos vírus, vermes (*worms*) e ‘cavalos de Tróia’, causando pânico e prejuízos para um grande número de organizações.
- ☛ O avanço nas pesquisas de clonagem pode resultar em mais problemas envolvendo a segurança, principalmente relativos à biometria (Capítulo 11), a qual vem sendo desenvolvida para minimizar problemas existentes nas tecnologias tradicionais de autenticação.

3.3 SEGURANÇA COMO PARTE DOS NEGÓCIOS

Nas décadas de 70 e 80, a informática fazia parte da retaguarda dos negócios das organizações, nas quais o enfoque principal da segurança era o sigilo dos dados. Era a época dos mainframes, e a proteção era voltada para os dados. Entre as décadas de 80 e 90, com o surgimento dos ambientes de rede, a integridade passou a ser de suma importância, e a proteção era feita não tendo em mente os dados, mas sim as informações. A informática fazia parte da administração e da estratégia da organização. A partir da década de 90, o crescimento comercial das redes baseados em *Internet Protocol* (IP) fez com que o enfoque fosse mudado para a disponibilidade. A informática, agora, tornou-se essencial nos negócios, e o conhecimento é que deve ser protegido.

Pode-se definir os dados como um conjunto de bits armazenados, como nomes, endereços, datas de nascimento, números de cartões de crédito ou históricos financeiros. Um dado é considerado uma informação quando ele passa a ter um sentido, como as informações referentes a um cliente especial. O conhecimento é o conjunto de informações que agrega valor ao ser humano e à organização, valor este que resulta em uma vantagem competitiva, tão importante no mundo atual.

Neste mundo globalizado, onde as informações atravessam fronteiras com velocidade espantosa, a proteção do conhecimento é de vital importância para a sobrevivência das organizações. As dimensões dessa necessidade passam a influenciar diretamente os negócios. Uma falha, uma comunicação com informações falsas ou um roubo ou fraude de informações podem trazer graves consequências para a organização, como a perda de mercado, de negócios e, conseqüentemente, perdas financeiras. Desse modo, a proteção, não só das informações e de seu capital intelectual, mas também de todos os recursos envolvidos na infra-estrutura de rede, deve ser tratada com a devida importância. E como o conhecimento é o principal capital das organizações, protegê-lo significa proteger o seu próprio negócio. Assim, a segurança passa a fazer parte do processo de negócios das organizações.

O grande problema é que muitos processos de negócios não foram concebidos no contexto de um ambiente distribuído e de redes, e muitos outros foram desenvolvidos sem o enfoque na segurança, mas com a abordagem ‘se funcionar, está ótimo’.

O resultado disso é uma aplicação de ‘remendos’ para os problemas de segurança, sem uma estratégia e uma arquitetura de segurança que protejam de fato a organização. Essa abordagem de ‘remendos’ é considerada melhor do que a inexistência de

qualquer abordagem, porém ela cria um falso senso de segurança, que é muito perigoso, e muitas vezes pior do que não ter segurança alguma. De fato, a superficialidade e a utilização de técnicas parciais e incompletas pode aumentar a vulnerabilidade da organização. Sem um plano e uma arquitetura de segurança bem definidos, as tecnologias de segurança podem ser mal interpretadas e mal utilizadas — como o *firewall*, que, se for mal configurado e mal utilizado, não tem função nenhuma na rede. Aliás, achar que o *firewall* resolve os problemas de segurança é um dos grandes erros disseminados entre as organizações. Isso poderá ser visto ao longo da leitura deste livro.

A estreita relação entre a segurança e os negócios pode ser vista no seguinte exemplo: na medida em que as organizações migram para a Web, vendendo seus produtos diretamente ao consumidor, por meios eletrônicos, a segurança passa a ser o ‘coração’ dessa venda. A transmissão do número do cartão de crédito deve ser segura, os dados do consumidor devem ser protegidos e os dados do cartão de crédito recebidos devem ser muito bem armazenados. Assim, a segurança passa a ser, em um primeiro momento, o principal responsável pelo negócio, o elemento que permite que a venda realmente aconteça. Se, em outros tempos, o setor comercial era o responsável pelas decisões de vendas, hoje, no mundo eletrônico, o profissional de segurança tem um papel importante, influenciando diretamente nos negócios da organização. É ele o responsável pela definição e implementação da estratégia de segurança das transações eletrônicas e pelo armazenamento de todas as informações. O profissional de segurança passa, assim, de uma posição técnica obscura para a linha de frente dos negócios da organização.

Um caso que mostra claramente a forte ligação entre segurança e comércio eletrônico é o da loja virtual de CDs *CD Universe*. Após a base de dados dos clientes, que continha 300 mil números de cartões de crédito, ter sido roubada, sua reputação ficou seriamente comprometida, de modo que seus antigos clientes passaram a não confiar mais na loja [INT 00]. Um outro exemplo em que fica claro que a segurança tem uma forte ligação e grande influência nos negócios é o próprio ambiente cooperativo. O sucesso, muitas vezes, depende da comunicação segura entre matrizes, filiais, fornecedores, parceiros comerciais, distribuidores e clientes.

Assim, a segurança da informação e os negócios estão estritamente ligados. Hoje, o profissional de segurança está partindo para um trabalho mais orientado a essa nova realidade, na qual ele tem de ouvir as pessoas, de modo a entender e saber como aplicar as tecnologias de acordo com a organização, sua estratégia de negócios, suas necessidades e sua estratégia de segurança.

3.4 COMO A SEGURANÇA É VISTA HOJE

Apesar de a segurança ser, atualmente, essencial para os negócios das organizações, a dificuldade em entender sua importância ainda é muito grande. Muitas vezes, a única segurança existente é a obscuridade. Criar redes sem proteção, achando que ninguém irá descobrir as brechas, configurar servidores particulares na organização para acesso doméstico ou o uso de chaves de criptografia no próprio código de um software são alguns maus exemplos que devem ser evitados. Essa obscuridade constitui um risco muito grande para a organização, pois, mais cedo ou mais tarde, alguém poderá descobrir que um grande tesouro está à sua completa disposição.

De fato, é apenas uma questão de tempo para que isso aconteça, causando grandes prejuízos, sejam eles financeiros, morais ou relacionados à reputação. E todos sabem que uma boa reputação pode demorar anos para ser construída, mas pode ser destruída em questão de instantes. É claro que esse aspecto depende da área de atuação da organização. Por exemplo, para um banco, um incidente de segurança, por menor que seja, fará com que seus clientes percam a confiança nos serviços prestados, e eles procurarão outros meios para movimentarem seus recursos financeiros. A grande questão, portanto, está na confiança. Os bancos trabalham com isso, de forma que o grande negócio deles tem como base a confiança obtida de seus clientes.

E é justamente nela que se baseia ou se basearão os negócios da maioria das organizações. Tudo isso como resultado da globalização da economia mundial e do aumento do número de conexões das organizações. Pode-se ver que a convergência para as redes é um processo natural, pois ela permite que os negócios sejam realizados de modo mais eficiente, dinâmico e produtivo, o que faz com que as relações entre as organizações e seus clientes, fornecedores, parceiros e funcionários dependam cada vez mais dessa estrutura. Portanto, os ambientes cooperativos são criados e crescem, desenvolvendo um novo modelo de negócios com base nas redes, e eles necessitam de um grande grau de confiança, para que funcionem de maneira adequada. Do mesmo modo que os bancos dependem da confiança que recebem de seus clientes, o mesmo ocorre com as demais organizações.

A organização que faz parte de um ambiente cooperativo deve entender que a segurança é essencial para o sucesso de seus negócios. Se nos bancos a relação de confiança existia entre a instituição e seus clientes, hoje, essa relação ocupa dimensões ainda maiores, na qual a confiança não deve existir apenas entre a organização e seus clientes, mas também entre a organização e seus fornecedores, parceiros, distribuidores e funcionários. Isso porque um incidente de segurança em um único ponto dessa rede pode comprometer todo o ambiente cooperativo.

Por exemplo, se em uma cadeia do processo de negócios, um fornecedor sofrer algum incidente de segurança, esse incidente pode alastrar-se por todos os outros pontos do ambiente cooperativo. Isso pode resultar em um rompimento das relações de confiança entre os pontos do ambiente cooperativo, pois a falha de um pode trazer prejuízos para todos.

A segurança ainda é um campo relativamente novo, e muitos ainda não conseguem enxergar sua importância, imaginando apenas que as soluções são caras e não trazem nenhum retorno financeiro. Apesar dessa visão estar evoluindo com o decorrer dos anos, ela faz com que os executivos prefiram aplicar seus recursos em novas soluções que possam trazer vantagens visíveis aos olhos de todos.

Esse é o maior desafio da segurança: uma solução de segurança é imensurável e não resulta em melhorias nas quais todos podem notar que alguma coisa foi feita. Pelo contrário, a segurança tem justamente o papel de evitar que alguém perceba que alguma coisa está errada. O fato é que ninguém percebe a existência da segurança, apenas a inexistência dela, quando um incidente acontece e resulta em prejuízos gigantescos. Sobre a segurança, ainda hoje se tem esse conceito de que ela é um artigo caro e dispensável, necessário somente quando algum ataque acontece e traz prejuízos à organização. Apesar dessa visão reativa, algumas organizações já vêem a segurança com outros olhos, passando a considerá-la como parte essencial do negócio. A formação de equipes dedicadas de segurança da informação é um indicativo desse fato. Nos Estados Unidos, 60% das empresas pesquisadas já possuem, pelo menos, uma pessoa dedicada ao assunto [WAR 03-2], enquanto no Brasil, 98% das empresas possuem, pelo menos, uma pessoa dedicada [MOD 02].

O que é realmente necessário é que o ambiente cooperativo seja analisado de acordo com sua importância e com os grandes benefícios que ele pode trazer à organização. É impossível que um ambiente cooperativo exista sem que as questões relacionadas à segurança sejam discutidas e solucionadas.

O grande ideal é que a segurança passe a ser um processo 'transparente' dentro das organizações, algo parecido com o que aconteceu com a qualidade. Todos começaram a buscar a qualidade em seus negócios, de tal forma que, hoje, quando qualquer serviço é prestado ou nem ao menos qualquer produto é vendido, estes devem ter qualidade, sem que isso seja sequer discutido. Não é mais uma questão de avaliar se é possível, mas sim de que é necessário ter qualidade. O mesmo caminho deverá ser seguido pela segurança. A questão não deve ser se existe ou não segurança, mas sim em que nível se encontra. Assim como a qualidade, ela deve ser considerada um pré-requisito do processo de negócios, pois se não existe a segurança, não existem os negócios. O princípio de que 'se funcionar, está bom', todos sabem adotar. Mas o conceito de que é preciso 'fun-

cionar com segurança' será o grande diferencial entre as organizações boas e confiáveis e as más, que não receberão a confiança necessária para o seu sucesso e tenderão ao fracasso.

Seguir a idéia de que a segurança e o ambiente cooperativo devem andar juntos trará, além de bons negócios, grandes benefícios à economia global e também a garantia de sobrevivência.

3.5 INVESTIMENTOS EM SEGURANÇA

Um dos principais obstáculos para a definição e implementação de mecanismos de segurança é o seu orçamento, comumente pequeno ou praticamente inexistente. Apesar disso estar mudando aos poucos, como poderá ser visto a seguir, o principal ponto a ser considerado é que, como foi visto no tópico anterior, os executivos geralmente não têm a visão necessária para enxergar a importância de uma boa estratégia de segurança.

Alguns executivos não se importam nem mesmo com a possível perda de credibilidade. Um caso recente aconteceu em fevereiro de 2003, com o fabricante de jogos eletrônicos Epic Games, Inc. Um pesquisador de segurança descobriu vulnerabilidades que atingiam vários jogos da Epic e enviou o alerta particularmente à empresa. Após 90 dias de tentativas em auxiliar a empresa a corrigir os problemas, e sem obter resposta coerente, o pesquisador divulgou o boletim de segurança. Somente após a divulgação pública é que a Epic finalmente agiu de uma forma coerente, como deveria ter acontecido desde o início [BUG 03].

Esse fato demonstra que, geralmente, a segurança é vista como um elemento supérfluo dentro das organizações, criando-se diversos mitos quanto ao assunto, os quais podem ser vistos na Seção 3.6. Como as próprias organizações têm orçamentos limitados, a segurança acaba ficando em segundo plano, geralmente vindo à tona apenas quando é extremamente necessária, ou seja, apenas quando a organização sofre algum incidente de segurança, como um ataque ao banco de dados ou a divulgação pública de material confidencial.

Essa visão reativa, com as decisões de segurança sendo tomadas apenas após um incidente, traz uma série de consequências negativas para a organização, principalmente no que se refere à perda de credibilidade e à resultante perda de mercado.

Isso acaba gerando um grande problema para os administradores de segurança, que acabam não tendo os recursos necessários para uma atuação de forma preventiva. É preciso fazer com que os executivos passem a considerar a segurança da organização como um elemento essencial para o seu sucesso neste mundo no qual as conexões fazem uma grande diferença no mercado. Esses executivos devem en-

tender que a solução de segurança não gera gastos, mas é um investimento habilitador de seus negócios, é o ponto-chave dentro dessa estratégia.

Felizmente, isso começou a mudar, fruto da evolução natural do mercado e também dos recentes acontecimentos que fizeram com que o assunto ficasse em evidência até mesmo nos noticiários mais tradicionais. Um dos primeiros eventos que tiveram exposição na mídia foram os vírus Melissa e ExploreZip, que causaram problemas à diversas organizações em 1999. Segundo a Computer Economics [COM 03], os prejuízos nos Estados Unidos em 1999 foram de 12,1 bilhões de dólares, dos quais 1,2 bilhão de dólares foram referentes ao Melissa. Já o vírus I Love You, ou Love Bug, causou, em 2000, um prejuízo de 6,7 bilhões de dólares somente nos seus cinco primeiros dias. Em 2000, os prejuízos chegaram a 17,1 bilhões de dólares, ou seja, um crescimento de mais de 40% com relação ao ano anterior. Já em 2001, os prejuízos estimados foram de 13,2 bilhões de dólares [COM 03]. Já o Slammer Worm, que atingiu um grande número de sistemas no início de 2003, causou prejuízos entre 950 milhões de dólares e 1,2 bilhão de dólares em perda de produtividade, nos cinco primeiros dias de contaminação [LEM 03][mi2g 03]. Os prejuízos causados pelos principais vírus podem ser vistos na Tabela 3.1:

Tabela 3.1 Prejuízos causados pelos principais vírus. Fonte: Computer Economics e mi2g.

Ano	Vírus	Prejuízos (em milhões de dólares)
1999	Melissa	1 200
2000	I Love You	8 750
2001	Nimda	635
2001	Code Red (variações)	2 620
2001	Sircam	1 150
2002	Klez	9 mil

Um outro acontecimento que despertou o interesse da mídia internacional foram os ataques distribuídos de negação de serviço ocorridos em fevereiro de 2000, os quais tornaram inacessíveis grandes sites como Amazon, Yahoo, UOL, E-Bay, Zipmail, entre outros. Segundo a Yankee Group, os prejuízos mundiais baseados em perda de capitalização, perda de receita e custos com atualização de mecanismos de segurança foram de 1,2 bilhão de dólares [DAMI 00].

Porém, os piores incidentes que influenciaram o mercado de segurança foram os atentados terroristas de 11 de setembro de 2001. Com as imensuráveis perdas, muitas organizações perderam tudo, desde seu capital humano e intelectual até suas informações. Isso fez com que a prevenção passasse a ser vista com mais interesse do que acontecia normalmente.

Esse fato pode ser comprovado pelo crescente aumento dos investimentos com segurança. Nos Estados Unidos, uma pesquisa indicou que serão investidos, em média, 10,3% do orçamento de tecnologia da informação em 2003, o que significa um aumento de 9,5% com relação a 2002 [WAR 03]. Segundo a pesquisa, mais de 33% das organizações possuem reservados mais de 1 milhão de dólares para 2003, enquanto 36% possuem orçamento entre 101 mil dólares e 1 milhão de dólares [WAR 03].

Outra pesquisa, da Meta Group, mostra que, apesar da diminuição do orçamento corporativo mundial, a área de segurança continua aumentando seu orçamento. Em 2001, 33% das organizações gastaram mais de 5% de seu orçamento com segurança e, no final de 2003, cerca de 55% das empresas gastarão mais de 5% do orçamento com segurança [MUL 02]. No Brasil, 77% das organizações pesquisadas pretendiam aumentar seus investimentos com segurança no decorrer de 2002 e 2003, enquanto que 21% pretendiam manter os mesmos valores [MOD 02].

É interessante notar que, para as organizações, os investimentos em segurança são considerados cada vez mais estratégicos, de modo que existe uma tendência de que a segurança possua seu próprio orçamento, separado dos recursos destinados à tecnologia da informação. Em 2002, 20% das organizações americanas possuíam orçamento próprio, e em 2003 essa porcentagem crescerá para 25% [WAR 03]. Atualmente, o que pode ser observado também é que a segurança física tende a possuir seu próprio orçamento, o que de fato acontece em 71% das organizações [WAR 03]. No Brasil, foram apontados que 78% das organizações possuem orçamento específico para a área de segurança, normalmente junto com o orçamento da tecnologia; 33% das organizações reservam entre 1 e 5% do orçamento de tecnologia para a área de segurança, enquanto que 24% das organizações reservam entre 5 a 10% do orçamento de tecnologia [MOD 02].

Nos Estados Unidos, os principais três assuntos mais importantes que têm recebido investimentos são a tecnologia (93%), a política (57%) e o pessoal (39%). Já a porcentagem do orçamento de segurança alocada para a tecnologia atinge 36%, seguidos pelo pessoal (23%), consultoria (11%), política (9%), processos (9%), educação (8%) e outros (4%). As empresas americanas ainda necessitam de aumento dos investimentos em tecnologia (61%), educação (51%), pessoal (41%), processos (33%), política (28%), consultoria e terceirização (16%) e outros (2%) [WAR 03-1]. No Brasil, os três principais assuntos que estão nos planos de investimentos são a capacitação da equipe técnica (81%), política de segurança (76%) e análise de riscos (75%) [MOD 02].

As pesquisas nos Estados Unidos e no Brasil indicam uma tendência clara do aumento da importância dos assuntos relacionados à segurança da informação den-

tro das organizações, quer sejam em termos de orçamento quer em investimentos com capacitação.

Desconsiderando-se os números referentes às pesquisas, os valores relacionados à segurança são difíceis de ser quantificados, pois o que está em jogo são, além dos recursos considerados tangíveis (horas de trabalho para a recuperação, equipamentos, software), os recursos intangíveis (valor do conhecimento, 'quebra' de sigilo, imagem da organização). Além disso, os cálculos sempre são feitos com base em suposições, tais como: "Se o sistema for atingido, teremos \$\$\$ de prejuízos, então, o melhor é investir \$\$\$ para a proteção dos recursos da organização".

O enfoque, nesse caso, é a identificação dos valores estimados das informações da organização e também o cálculo e a avaliação dos impactos nos negócios em caso de um incidente. Essa abordagem permite entender exatamente o que ocorre se a organização sofre danos nessas informações.

Assim, uma análise de riscos e uma metodologia para quantificar e qualificar os níveis de segurança de cada recurso da organização são importantes. Elas auxiliam na criação da proposta e das justificativas de investimentos para a implantação de um sistema de segurança adequado.

Essa abordagem, porém, é baseada no método do medo, incerteza e dúvida (*Fear, Uncertainty and Doubt* — FUD), ou seja, na possibilidade de perda em caso de um incidente. Como a análise é feita na base do "Se a organização não investir \$\$\$, os prejuízos serão de \$\$\$", e não com base em fatos concretos, os projetos de segurança eram vistos com certa reticência pelos executivos. É interessante observar que o próprio ser humano tem dificuldade em atuar de forma preventiva. Porém, após os atentados terroristas de 11 de setembro, os executivos passaram a dar mais importância a todos os aspectos de segurança, desde os pessoais até os tecnológicos. Os incidentes demonstraram, da pior maneira possível, os grandes prejuízos que podem ser causados. Foram imensas as perdas de materiais, informações, equipamentos, capital intelectual e capital humano.

Assim, a maior quantidade possível de informação ajuda na tomada de decisões sobre os investimentos com segurança, e a medição do retorno em investimentos de segurança (*Return on Security Investment* — ROSI) possui um papel importante nesse processo. Os principais benefícios indicados em uma pesquisa feita nos Estados Unidos foram a diminuição de brechas de segurança (75%), a redução de perdas financeiras (47%) e o aumento da satisfação dos clientes (29%) [WAR 03].

3.6 MITOS SOBRE SEGURANÇA

Diversos mitos sobre segurança são utilizados pelos executivos para 'tapar os olhos' com relação ao assunto. É interessante observar que, conforme o conhecimento sobre o assunto, o qual é abrangente, vai aumentando, a preocupação e o conjunto de ações a serem tomados também aumenta — enquanto que para aqueles que não conhecem os riscos não existe a preocupação com a segurança, pois a visão mais limitada faz com que eles pensem que tudo está bem. Como explicar o fato de que 32% das empresas brasileiras não sabem informar se, ao menos, sofreram um incidente de segurança [MOD 02]? Nos Estados Unidos, essa porcentagem é de 12% [CSI 02].

De fato, é comprovado que não é possível proteger os recursos de riscos que não se conhece — se não se conhece os riscos, para que a proteção? Alguns dos mitos mais comuns são:

- ☛ 'Isso nunca acontecerá conosco'.
- ☛ 'Nunca fomos atacados, não precisamos de mais segurança'.
- ☛ 'Já estamos seguros com o *firewall*'.
- ☛ 'Utilizamos os melhores sistemas, então, eles devem ser seguros'.
- ☛ 'Não dá para gastar com segurança agora, deixa assim mesmo'.
- ☛ 'Utilizamos as últimas versões dos sistemas dos melhores fabricantes'.
- ☛ 'Nossos fornecedores irão nos avisar, caso alguma vulnerabilidade seja encontrada'.
- ☛ 'Ninguém vai descobrir essa 'brecha' em nossa segurança'.
- ☛ 'Tomamos todas as precauções, de modo que os testes não são necessários'.
- ☛ 'Vamos deixar funcionando e depois resolveremos os problemas de segurança'.
- ☛ 'Os problemas de segurança são de responsabilidade do departamento de TI'.
- ☛ 'Luís, depois de instalar o Word para a Cláudia, você pode instalar o *firewall*'?
- ☛ 'A companhia de TI que foi contratada irá cuidar da segurança'.
- ☛ 'O nosso parceiro é confiável, podemos liberar o acesso para ele'.
- ☛ 'Não precisamos nos preocupar com a segurança, pois segurança é um luxo para quem tem dinheiro'.

Possuir bons argumentos para derrubar esses mitos significa conhecer bem os riscos que a organização está correndo, levando em consideração toda a diversidade de seu ambiente e toda a interação existente com outros ambientes.

Com isso, o profissional de segurança deve ter uma visão peculiar, de certa forma até mesmo um modo de vida, com foco total na proteção do ambiente. A

identificação de pontos de vulnerabilidades no ambiente depende muito dessa visão, que deve ser abrangente, crítica e completa.

3.7 RISCOS E CONSIDERAÇÕES QUANTO À SEGURANÇA

Diversos aspectos devem ser levados em consideração quando uma rede passa a constituir uma parte importante da organização. Alguns dos riscos existentes e algumas considerações a serem feitas são:

- ☛ A falta de uma classificação das informações quanto ao seu valor e à sua confiabilidade, que serve de base para a definição de uma estratégia de segurança adequada. Isso resulta em um fator de risco para a organização, além de dificultar o dimensionamento das perdas resultantes de um ataque.
- ☛ O controle de acesso mal definido faz com que os usuários, que são autenticados no início da conexão, tenham acesso irrestrito a quaisquer partes da rede interna, até mesmo a partes do sistema que não são necessárias para a realização de suas tarefas.
- ☛ A dificuldade de controle do administrador sobre todos os sistemas da rede interna faz com que estes não possam ser considerados confiáveis. Os 'bugs' nos sistemas operacionais ou nos softwares utilizados por esses equipamentos podem abrir 'brechas' na rede interna, como pode ser visto na Seção 4.6.1.
- ☛ A Internet deve ser considerada um ambiente hostil e, portanto, não confiável. Assim, todos os seus usuários devem ser considerados não confiáveis e potenciais atacantes.
- ☛ As informações que trafegam pela rede estão sujeitas a serem capturadas.
- ☛ As senhas que trafegam pela rede estão sujeitas a serem capturadas.
- ☛ Os e-mails podem ser capturados, lidos, modificados e falsificados.
- ☛ Qualquer conexão entre a rede interna e qualquer outro ponto pode ser utilizada para ataques à rede interna.
- ☛ Os telefones podem ser grampeados e as informações que trafegam pela linha, seja por voz ou dados, gravadas.
- ☛ Os firewalls protegem contra acessos explicitamente proibidos, mas e quanto a ataques contra serviços legítimos?
- ☛ Quando se adota a 'segurança pela obscuridade', situação em que a organização pensa que sua rede nunca será invadida porque não é conhecida, os responsáveis 'torcem' para que o invasor não saiba dos problemas com segurança e dos valores disponíveis na rede interna. Até quando?
- ☛ Novas tecnologias significam novas vulnerabilidades.

- ☛ A interação entre diferentes ambientes resulta na multiplicação dos pontos vulneráveis.
- ☛ A segurança envolve aspectos de negócios, tecnológicos, humanos, processuais e jurídicos.
- ☛ A segurança é complexa.

Essas considerações mostram o quanto a segurança é abrangente e multidisciplinar. Cuidar de alguns pontos e negligenciar outros pode comprometer totalmente a organização, pois os incidentes sempre ocorrem no elo mais fraco da corrente, ou seja, no ponto mais vulnerável do ambiente.

Assim, uma estratégia de segurança baseada em um modelo, como o Modelo de Teias (Capítulo 13), passa a ser essencial para que todos os pontos sejam analisados. A Figura 3.5 mostra os pontos a serem analisados e defendidos para que a informação seja protegida adequadamente. É possível observar que todos os níveis devem ser considerados para que a informação, que é o maior bem da organização, seja protegida. Partindo do sistema operacional, devem ser avaliados e considerados, ainda, os serviços, os protocolos, as redes, as aplicações, os usuários e as instalações físicas envolvidas com a informação.

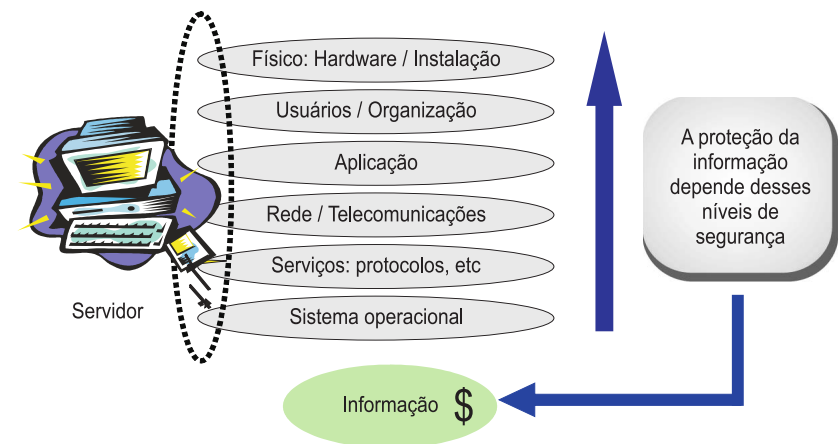


Figura 3.5 A abrangência da segurança e a complexidade da proteção da informação.

3.8 SEGURANÇA VERSUS FUNCIONALIDADES

Até pouco tempo atrás, as organizações implementavam suas redes apenas com o objetivo de prover funcionalidades que permitiam promover a evolução de seus

processos organizacionais internos. A preocupação com a segurança praticamente não existia, pois o contato com o mundo exterior era limitado. Hoje, porém, o mundo exige que as redes das organizações sejam voltadas para o seu próprio negócio, com a formação de um ambiente cooperativo, requerendo, assim, a segurança. Uma característica que pode ser vista é que, em um primeiro momento, a falta de um planejamento em segurança pode parecer uma boa situação, pois tudo funciona adequadamente. No entanto, os problemas de segurança invariavelmente aparecem depois, o que pode resultar em custos estratosféricos para que sejam resolvidos, principalmente, em grandes ambientes.

A importância da segurança cresce ainda mais rapidamente, quando se leva em consideração o rápido aumento da complexidade das conexões, característico dos ambientes cooperativos. Um ponto fundamental, quando se discute o assunto, é que a segurança é inversamente proporcional às funcionalidades, ou seja, quanto maiores as funcionalidades, como serviços, aplicativos e demais facilidades, menor é a segurança desse ambiente. Isso pode ser explicado, porque a segurança pode ser comprometida pelos seguintes fatores:

- ☛ Exploração da vulnerabilidade em sistemas operacionais, aplicativos, protocolos e serviços.
- ☛ Exploração dos aspectos humanos das pessoas envolvidas.
- ☛ Falha no desenvolvimento e implementação da política de segurança.
- ☛ Falha na configuração de serviços e de sistemas de segurança.
- ☛ Desenvolvimento de ataques mais sofisticados.

Esses tópicos serão vistos com mais detalhes no Capítulo 4. Quando as vulnerabilidades que podem existir em sistemas operacionais, aplicativos, protocolos e serviços são analisadas, pode-se considerar que elas são resultantes de 'bugs', que são decorrentes de falhas em seu código, em seu projeto ou em sua configuração.

Assim, quanto maior for o número de sistemas, maior é a responsabilidade dos administradores e maior é a probabilidade de existência de 'bugs' que podem ser explorados. Um estudo da IDC propôs uma fórmula para determinar os pontos de vulnerabilidade de uma rede: o número de pontos de vulnerabilidade é igual ao número de recursos críticos da organização, multiplicado pelo número de usuários que têm acesso a esses recursos. Assim, se um servidor NT tem dez mil arquivos e cem usuários, existe um milhão de possíveis pontos de acesso vulneráveis. A previsão de todas as brechas é impraticável, principalmente porque o fator humano está envolvido, o que significa, por exemplo, que a escolha das senhas por cada um dos usuários influi diretamente no nível de segurança do ambiente [BRI 99B]. Além

disso, existe ainda a complexidade, que aumenta com as interações, e o perigo das triangulações, que influem diretamente na segurança do ambiente.

O objetivo, portanto, é equilibrar a segurança com os riscos, minimizando os impactos que uma falha de segurança pode causar à organização. As obrigações dos administradores quanto à manutenção da segurança devem estar claramente definidas na política de segurança da organização. Ela especifica as responsabilidades do acompanhamento das novidades e dos boletins sobre os sistemas que estão sendo utilizados na organização, principalmente quanto a relatórios de segurança e instalação de *patches* de correção. Estes e outros pontos referentes à política de segurança serão discutidos no Capítulo 6.

3.9 SEGURANÇA *VERSUS* PRODUTIVIDADE

A administração da segurança de uma organização é uma tarefa complexa, na medida em que ela deve ser dimensionada, sem que a produtividade dos usuários seja afetada.

Geralmente, a segurança é antagônica à produtividade dos usuários, no sentido de que, como foi visto no tópico anterior, quanto maiores as funcionalidades, maiores as vulnerabilidades existentes. Isso leva os administradores a restringirem ao máximo os serviços que os usuários podem acessar, de modo a minimizar os riscos existentes.

O problema é que uma política de segurança muito restritiva geralmente afeta a produtividade do usuário. Por exemplo, se o FTP for bloqueado com o objetivo de prevenir a entrada de 'cavalos de Tróia', e o usuário necessita utilizar esse serviço para o seu trabalho, ele certamente buscará maneiras de 'driblar' essa restrição do *firewall*. O usuário poderá instalar um modem em seu equipamento ou tentar achar 'brechas' no bloqueio do *firewall*. Quando isso acontece, os objetivos não são alcançados, pois a segurança é comprometida pelas ações dos usuários, e sua produtividade é prejudicada, pois eles perdem tempo tentando encontrar maneiras de 'driblar' o *firewall*.

Por isso, é importante ter uma política de segurança bem definida e bem balanceada, tanto com relação aos serviços externos quanto aos serviços internos que os usuários, internos e externos, podem acessar. O objetivo é criar uma política que defina, de forma ideal, apenas os serviços realmente necessários. Outro ponto a ser considerado na definição desses serviços que serão permitidos é quanto a serviços como RealAudio, ICQ e sessões de bate-papo, que constituem um problema, pois comprometem o nível de produtividade da organização, além de consumir grande largura de banda da rede. Alguns deles, como o ICQ, ainda introduzem novas vulnerabilidades à rede interna da organização.

3.10 UMA REDE TOTALMENTE SEGURA

A segurança é complexa, envolvendo aspectos de negócios, processos humanos, jurídicos, tecnológicos, e outros. Portanto, afirmar que uma organização está 100% segura é, na realidade, um grande erro. Simplesmente não existe um modelo de segurança à prova de *hackers*. Será visto, no Capítulo 4, que os *hackers* podem atuar de diversas maneiras, e mesmo os próprios funcionários maliciosos podem fazer esse papel de *hacker* (*insiders*). Uma vez que a segurança envolve aspectos tecnológicos (o melhor sistema de autenticação), aspectos técnicos (um bom administrador de segurança), aspectos sociais (funcionários inescrupulosos que roubam informações confidenciais da própria organização), aspectos humanos (funcionários inocentes que sofrem com a engenharia social) e aspectos educacionais (funcionários que devem saber, pelo menos, como escolher senhas seguras), com toda essa complexidade, o objetivo das organizações deve ser tentar proteger ao máximo os recursos da organização e não tentar protegê-los totalmente.

Diversos aspectos contribuem para medir essa 'máxima proteção'. Entre eles, está: definir os recursos que devem ser protegidos, especificar quem irá administrar a segurança e, principalmente, determinar o valor que será utilizado como investimento em segurança.

No mínimo, essa segurança inclui uma política e procedimentos abrangentes, o controle dos usuários e a autenticação de todos os meios de acesso ao sistema, transações e comunicações. Inclui também a proteção dos dados, além do constante monitoramento e a evolução do nível de segurança geral. Outro ponto importante é que as novas técnicas e tecnologias devem ser utilizadas antes que os *hackers* as utilizem contra a organização.

A segurança de perímetro e a abordagem em camadas, nas quais vários mecanismos de segurança são adotados de forma encadeada, também são importantes. Dessa forma, as camadas de segurança funcionariam como os catafilos da cebola, que protegem o seu interior. Cada uma dessas camadas tem de ser transposta pelo *hacker* para que ele chegue ao seu objetivo, que é o acesso à informação. Quanto maior o número de camadas, maior a dificuldade de atacar o recurso.

Assim, a tentativa de estabelecer uma segurança total pode 'levar à loucura'; a segurança parcial, por definição, assume os riscos. As organizações, portanto, devem definir o nível de segurança, de acordo com suas necessidades, já assumindo esses riscos. Isso faz com que o plano de contingência seja um dos pontos essenciais dentro do esquema de segurança de uma organização.

O objetivo não é construir uma rede totalmente segura, mas sim um sistema altamente confiável, que seja capaz de anular os ataques mais casuais de *hackers* e também de tolerar acidentes, como a possibilidade de um tubarão romper os cabos

de transmissão localizados no mar. As falhas benignas devem ser toleradas pelos sistemas. Essas vulnerabilidades devem ser colocadas em um lugar no qual não possam causar problemas. Uma rede nunca será totalmente segura, mas deve-se procurar meios de torná-la, no mínimo, mais confiável, como está descrito no artigo "*Trust in Cyberspace*" [KRO 99].

3.11 CONCLUSÃO

Com a rápida evolução que pode ser acompanhada no mundo dos negócios, no qual as conexões entre organizações significam vantagens competitivas, a segurança de redes passa a ser mais do que fundamental; ela passa a ser o habilitador dos negócios. Porém, captar investimentos para a implementação de uma estratégia de segurança envolve diversos desafios, nos quais os riscos e os mitos de segurança devem ser combatidos. As funcionalidades envolvidas com o andamento dos negócios, bem como a produtividade dos usuários, são afetadas com as medidas de segurança adotadas, de modo que elas devem ser bem avaliadas e estudadas para que não causem impactos significativos para os envolvidos. A segurança é necessária, porém sua estratégia de implementação deve ser bem definida, medindo-se custos e benefícios e assumindo-se riscos, pois a segurança total não é possível.